

Daily Vulnerability Report - 2026-09-10

Window (UTC): 2026-09-10T00:00 to 2026-09-11T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 13:18:49 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
648	625	13	10	10	57	195	136	267	39

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-60004	New				0.868	Go:code.gitea.io/gitea, Go:gitea.dev	Gitea: Remote Code Execution via diffpatch Git Hook Installation in gitea.dev
CVE-2026-77770	New	10.0	CRIT		0.002		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not require a validated transaction before deleting site options whose names come from unauthenticated request input, allowing any visitor to delete arbitrary options, which can lock every administrator out of the dashboard or deactivate every miniOrange 2FA WordPress plugin...
CVE-2026-19583	New	9.9	CRIT		0.006		Velociraptor allows some sensitive artifacts to be gated by additional permissions. For example, the Linux.Sys.BashShell artifact allows arbitrary command execution on endpoints, and so it requires the EXECVE permission to schedule. However, no such check was implemented for client monitoring artifacts. Additionally there was no requirement that client monitoring artifacts c...
CVE-2026-68487	New	9.9	CRIT		0.004		Path traversal in Plesk's Backup Manager causes arbitrary file write as root by an authenticated customer.
CVE-2026-68488	New	9.9	CRIT		0.002		A Time-of-check Time-of-use (TOCTOU) race condition leading to insecure symlink following in Plesk causes local privilege escalation to root via arbitrary file/directory ownership takeover.
CVE-2026-89094	New	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2026-18351	New	9.8	CRIT		0.008		The Drag and Drop File Upload for Elementor Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.6.0 via the elementor_file_upload function. This is due to insufficient file type validation in the is_file_type_valid() function, which uses the attacker-controlled 'type' parameter as regex keys in the MIME allowlist, allowin...
CVE-2026-38626	New	9.8	CRIT		0.003		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-52098	New	9.8	CRIT		0.008	flowiseai:flowise	An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowid> endpoint

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57967	New	9.8	CRIT		0.007	apache:artemis	An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-7188	New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows SQL Injection. This issue affects Access Control System: before Versiyon 2.
CVE-2026-78573	New	9.8	CRIT		0.004	ibm:contextforge	IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-79724	New	9.8	CRIT		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-80351	New	9.8	CRIT		0.005	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privile...
CVE-2026-80352	New	9.8	CRIT		0.004	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9...
CVE-2026-81204	New	9.8	CRIT		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467	New	9.8	CRIT		0.038	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-85025	New	9.8	CRIT		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-88018	New	9.8	CRIT		0.005	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, wh...
CVE-2026-88278	New	9.8	CRIT		0.003		GeoVision GV-LPC2211 V1.13 fails to enforce WS-Security UsernameToken freshness or nonce reuse protection, allowing a captured PasswordDigest token to be replayed for subsequent ONVIF operations.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-9163	New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.
CVE-2026-82107	New	9.6	CRIT		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-44950	New	9.5	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) copies each glyph's bitmap into a single buffer. Existing checks validates only that the source slice (position, length) lies within the source bitmap buffer. It does not check whether the running destination cursor has exceeded the allocation. A malicious font server can send overlapping source offsets ...
CVE-2026-65639	New	9.5	CRIT		0.016		OS command injection in the advanced-rule parser of ConfigServer Security & Firewall allows a remote attacker who controls a configured allow/deny feed to execute arbitrary commands as root, due to insufficient validation of feed-supplied rule data. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebProS-...
CVE-2026-88062	New	9.5	CRIT		0.009	npm:omniroute	OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called re...
CVE-2026-81046	New	9.4	CRIT		0.004	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-88285	New	9.4	CRIT		0.003		GeoVision GV-LPC2211 V1.13 exposes a network-accessible PTZ control service without authentication, allowing remote clients to retrieve PTZ information and issue PTZ or raw serial commands.
CVE-2026-75940	New	9.3	CRIT		0.003		A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.
CVE-2026-78082	New	9.3	CRIT		0.005		Joomla Extension - joomshaper.com - Unauthenticated SQL Injection in Property Search and Map Filtering in SP Property < 4.1.4 - The property search and listing query builders assembled several WHERE and ORDER BY clauses (zipcode, sorting, price_range_dropdown, and psize_range_dropdown) by directly concatenating raw request parameters into SQL strings without quoting or type ...
CVE-2026-81800	New	9.3	CRIT		0.002		Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-8323	New	9.3	CRIT		0.003		URL redirection to untrusted site ('open redirect') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows Fake the Source of Data. This issue affects Access Control System: before Versiyon 2.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88864	New	9.3	CRIT		0.003		Capgo (capgo.app) fails to restrict direct write access to the public.sso_providers table exposed through Supabase PostgREST. A holder of an ordinary Capgo full API key can insert a row with status='active' and enforce_sso=true, bypassing the intended backend SSO provisioning route (supabase/functions/_backend/private/sso/providers.ts) and its controls: the Enterprise plan r...
CVE-2026-88866	New	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the L...
CVE-2026-88867	New	9.3	CRIT		0.003		WWBN AVideo, in versions up to and including commit c3edcc274c389816d434acadac07ee78eaf330c1, contains a stored cross-site scripting vulnerability. objects/categoryAddNew.json.php passes the POST parameters `name` and `iconClass` to Category::setName() and Category::setIconClass(), which store the values without sanitization (setName only truncates to 45 characters). The cat...
CVE-2026-88868	New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LiveLinks plugin where title and description fields are stored without sanitization. A user with canStream permission can inject malicious scripts that execute in the browser of every visitor viewing the live-link page, including administrators, within t...
CVE-2026-88869	New	9.3	CRIT		0.005		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the AD_Server plugin's log.php endpoint that fails to escape the label parameter before storage. An unauthenticated attacker can inject malicious HTML through the label parameter, which is later rendered unsanitized in the admin Ad Types report using jQuery ...
CVE-2026-88877	New	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only...
CVE-2026-88899	New	9.3	CRIT		0.004		knowns versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89042	New	9.3	CRIT		0.003		passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-13745	New	9.2	CRIT		0.003		A vulnerability in the Gemini CLI and associated GitHub Action allowed an unprivileged attacker to achieve an arbitrary code execution in Gemini CLI via untrusted local .env files overriding GEMINI_CLI_HOME.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59679	New	9.2	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) indexes the per-character encoding[] array using num_chars from the FS_QueryXBitmaps16 reply, but that array was allocated with a size derived from num_extents in the separate FS_QueryXExtents16 reply. The two CARD32 fields are never cross-checked. A malicious or compromised font server can send a small n...
CVE-2026-65638	New	9.2	CRIT		0.032		Improper escaping of a request URL in ConfigServer Security & Firewall allows an unauthenticated remote attacker to execute arbitrary commands as the CSF service account via shell command injection. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnerable code. ...
CVE-2026-88881	New	9.2	CRIT		0.003		Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the 'next' page. Because the pagination URL is not validated against the host originally contacted, a...
CVE-2026-88882	New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. In versions before 44.11.2 (and Mend Renovate CE/EE images and charts before 15.4.0, and mend-renovate-enterprise-edition helm chart before 10.4.0), when listing new package versions from a NuGet registry Renovate follows pagination URLs supplied by the registry in the HTTP `Link` header without verifying that the target has t...
CVE-2026-88887	New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. When listing tags/digests for a container image, Renovate follows pagination links supplied by the remote registry in the HTTP Link header and attaches the registry credentials to the follow-up request without verifying that the pagination URL has the same origin as the original registry. A malicious or compromised container r...
CVE-2026-19646	New	9.1	CRIT		0.005		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-45764	New	9.1	CRIT		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workarou...
CVE-2026-49364	New	9.1	CRIT		0.004	apache:artemis	An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-67593	New	9.1	CRIT		0.006	apache:artemis	A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to versi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68006	New	9.1	CRIT		0.004		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file
CVE-2026-71640	New	9.1	CRIT		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline
CVE-2026-78361	New	9.1	CRIT		0.003		The zipMoney(Zip Co) Payments Plugin for WooCommerce WordPress plugin before 2.4.0 does not perform any authorisation checks on one of its front-end request handlers, and does not restrict which option name a caller may supply, allowing unauthenticated users to delete arbitrary WordPress options. This can be used to destroy site and access control configuration, deactivate e...
CVE-2026-80424	New	9.1	CRIT		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-84939	New	9.1	CRIT		0.008	apache:freemarker	Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling lo...
CVE-2026-88007	New	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication...
CVE-2026-88008	New	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.26 until 2.11.57 and 3.7.13, Traefik forwards a client-supplied Connection header requesting Upgrade, the Upgrade: h2c token, and HTTP2-Settings to a shared backend. If the backend accepts h2c and returns 101 Switching Protocols, Traefik enters a raw tunnel and no longer applies routers, BasicAuth, For...
CVE-2026-88044	New	9.1	CRIT		0.005	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.70.0 until 1.75.1, the serve/start RC interface accepts per-server proxyOpt.AuthProxy settings, and the FTP and S3 constructors in cmd/serve/ftp/ftp.go and cmd/serve/s3/server.go incorrectly check the process-global proxy.Opt.AuthProxy value instead. When the ...
CVE-2026-89086	New	9.1	CRIT		0.002		In the jose package before 0.11.0 for OCaml, library calls to validate an RSA signature only confirm that PKCS #1 decoding succeeds, and proceed to declare the signature valid without the required steps that involve the public key.
CVE-2026-75624	New	8.8	HIGH		0.004	ibm:aix, ibm:app_connect_enterprise, linux:linux_kernel, microsoft:windows	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.27 could allow a remote authenticated attacker to bypass security restrictions due to incorrect authorization.
CVE-2026-75777	New	8.8	HIGH		0.001		IBM Aspera Enterprise WebApps 1.0.0 through 1.0.5 could allow a local attacker to escape container protections due to unrestricted system calls being permitted within the container.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76059	New	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 An attacker who could submit custom component source code could bypass the static security scanner by crafting an annotated class-body assignment that resolved to a dangerous callable through alias tracking; the resolved value was never checked against the dangerous callable blocklist due to the logic error. If the crafted component reac...
CVE-2026-78569	New	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow an authenticated attacker to execute arbitrary code due to an incomplete denylist in the security scanner.
CVE-2026-78571	New	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an unguarded eval() call on attacker-controlled input.
CVE-2026-78575	New	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary commands due to improper validation of command-line arguments in the MCP stdio server configuration.
CVE-2026-79742	New	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to an incomplete environment variable blocklist.
CVE-2026-81048	New	8.8	HIGH		0.013	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Remote Code execution
CVE-2026-81211	New	8.8	HIGH		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary Python code due to improper authorization of custom components in stored flows.
CVE-2026-81550	New	8.8	HIGH		0.006	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-81940	New	8.8	HIGH		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special characters in flow display names.
CVE-2026-81941	New	8.8	HIGH		0.008	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 allows an authenticated non-administrative user could execute arbitrary operating system commands on the server at the privilege level of the application process by constructing a flow with an MCP Tools component configured to use a local stdio subprocess transport. This bypasses both the LANGFLOW_CUSTOM_COMPONENT_ADMIN_ONLY and LANGFLOW...
CVE-2026-82095	New	8.8	HIGH		0.006	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-82097	New	8.8	HIGH		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to a Server-Side Request Forgery (SSRF) vulnerability.
CVE-2026-82098	New	8.8	HIGH		0.008	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82099	New	8.8	HIGH		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper neutralization of special elements used in an OS command.
CVE-2026-84889	New	8.8	HIGH		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.10.3 could allow a remote authenticated attacker to execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-85228	New	8.8	HIGH		0.004		An integer overflow in the tensor buffer validation component in Amazon Deep Java Library (DJL) from 0.13.0 through 0.36.0 on all platforms might allow a remote unauthenticated actor to obtain information from adjacent process memory or cause a denial of service via a crafted tensor payload. To remediate this issue, users should upgrade to version 0.37.0 or above.
CVE-2026-88271	New	8.8	HIGH		0.002		GeoVision GV-LPC2211 V1.13 allows a Guest user to overwrite device configuration and replace the administrator password through SSVR.
CVE-2026-88277	New	8.8	HIGH		0.003		GeoVision GV-LPC2211 V1.13 allows an authenticated ONVIF user to inject shell commands through ConsumerReference.Address and execute arbitrary commands as root.
CVE-2026-88937	New	8.8	HIGH		0.005		knowns through 0.33.0 fails to properly validate template destination paths in the code generation template engine, allowing attackers to read and write arbitrary files outside the project root. Attackers can supply malicious templates that traverse directories to overwrite shell profiles, steal credentials, or achieve persistent code execution on victim systems.
CVE-2026-89046	New	8.8	HIGH		0.006		zstd-jni versions 1.5.5-6 through 1.5.7-13 contain an out-of-bounds read vulnerability in Zstd.getFrameContentSize that fails to validate negative srcPosition arguments. Attackers can supply negative offset values that bypass bounds checks and reach the native frame-header parser, causing out-of-bounds memory reads that lead to information disclosure or JVM crashes.
CVE-2026-16174	New	8.7	HIGH		0.001		Netskope was notified about a potential gap in Netskope Endpoint DLP (EPDLP) running on Windows systems. Successful exploitation of the gap could potentially allow a privileged user to send a crafted message to the EPDLP process port to trigger an integer overflow, leading to memory corruption. Successful exploitation would require the EPDLP module to be enabled in the client...
CVE-2026-64836	New	8.7	HIGH		0.004		ICEcoder versions through 8.1 contain a path traversal vulnerability in the file-control endpoint due to a logic error in the document-root confinement check. The File::check() validation function compares realpath() to boolean true, which never succeeds, allowing authenticated attackers to submit traversal sequences or absolute paths in the file parameter to read, write, or...
CVE-2026-64837	New	8.7	HIGH		0.005		ICEcoder through 8.1 passes an unescaped filesystem path into a shell command in lib/properties.php, allowing authenticated users to inject OS commands through directory names. Attackers can create directories with shell metacharacters in their names and access the Properties function to execute arbitrary commands as the web-server user via popen().

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-64838	New	8.7	HIGH		0.005		ICEcoder versions through 8.1 fail to properly validate the oldFileName parameter in file move and rename operations, allowing authenticated users to relocate files from outside the document root. Attackers can use path traversal sequences in oldFileName to move files writable by the PHP process into the web-accessible project directory, disclosing file contents and deleting...
CVE-2026-73693	New	8.7	HIGH		0.018		FileRun before 2026.3.0 contains an OS command injection vulnerability in the PhotoProofSheet handler that allows authenticated users with upload permission to execute arbitrary commands by uploading files with shell metacharacters in their names. Attackers can upload a file containing command substitution syntax such as backticks, semicolons, or \$() sequences in the filename...
CVE-2026-79987	New	8.7	HIGH		0.004		A remote, authenticated, non-admin Craft CMS Control Panel user with only the accessCp permission can execute operating system commands as the PHP web worker.
CVE-2026-87962	New	8.7	HIGH		0.004		t-digest versions 3.1 through 3.3 contain a denial of service vulnerability in MergingDigest.fromBytes that fails to validate length and capacity fields from serialized data. Attackers can supply crafted serialized digests with mismatched header fields to trigger ArrayIndexOutOfBoundsException or NegativeArraySizeException, aborting the parsing thread.
CVE-2026-88861	New	8.7	HIGH		0.003		Capgo (Cap-go/capgo.app) contains an authentication bypass affecting all versions (no patched version available at time of publication). The Edge authorization path allows a password-only Supabase aal1 session to exercise privileged RBAC permissions even when the account has a verified MFA factor that has not been used for the session: the Edge JWT middleware (foundJWT) in ...
CVE-2026-88862	New	8.7	HIGH		0.003		Capgo (capgo.app) backend through 12.242.4 does not validate parent-child delegation when processing the x-limited-key-id header. checkKeyByIdPg() in supabase/functions/_backend/utis/hono_middleware.ts resolves the attacker-supplied numeric API key ID using only the key ID, its expiration state, and the authenticating key's user_id, while hasLimitedRbacSubkeyScope() accepts...
CVE-2026-88874	New	8.7	HIGH		0.005		AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) does not enforce the Live stream password check on the stats endpoint or on the HLS origin. Live::_getStats() (plugin/Live/Live.php) returns a password-protected transmission's RTMP stream key, its isPasswordProtected flag, and its HLS (m3u8) URL to unauthenticated callers, in both the publ...
CVE-2026-88876	New	8.7	HIGH		0.003		AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 contains a missing authorization vulnerability in plugin/PlayerSkins/seu.php that allows unauthenticated attackers to access password-protected video sources by calling getSources() without password validation. Attackers can request the seu.php endpoint with a video ID to obtain the direct MP4 URL and read prot...
CVE-2026-88893	New	8.7	HIGH		0.003		OpenPanel share lookup procedures fail to validate access controls and return password hashes and protected report definitions to unauthenticated callers. Attackers with a share link can retrieve argon2id password hashes and full report configurations including event names, filters, and breakdown dimensions for offline password cracking and business intelligence theft.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88939	New	8.7	HIGH		0.003		knowns through 0.33.0 exempts the project.set action from permission guard checks unconditionally, allowing read-only agent sessions to bypass restrictions. Attackers can invoke project.set to repoint the server at another project directory and obtain write access capabilities.
CVE-2026-88959	New	8.7	HIGH		0.003		Anchor CMS through 0.12.7 fails to enforce role-based access control in admin user-management endpoints, allowing any authenticated low-privilege user to create administrator accounts or modify existing ones. Attackers with editor or user roles can POST directly to admin/users/add or admin/users/edit endpoints to create new administrator accounts or change the existing admin...
CVE-2026-4129	New	8.6	HIGH		0.002		There is an improper access control vulnerability in NI SystemLink that may allow an authenticated user with limited privileges to access host operating system files and directories that should be restricted. This vulnerability affects NI SystemLink and NI SystemLink Server versions prior to 2026 Q3.
CVE-2026-73694	New	8.6	HIGH		0.018		FileRun before 2026.3.0 contains an OS command injection vulnerability caused by a no-op redefinition of escapeshellcmd() in CLI.php that strips shell-metacharacter escaping, allowing attacker-controlled input to reach an exec() sink unsanitized. Attackers can exploit this through an interactive path via image_preview.php with a crafted args parameter requiring superuser aut...
CVE-2026-73698	New	8.6	HIGH		0.004		FileRun before 2026.3.0 contains a SQL injection vulnerability that allows delegated or simple administrators to execute arbitrary SQL by submitting the description parameter as an array, causing the getValuesString() method in DB/DP.php to interpolate raw array values directly into an INSERT statement without parameterization. Because the underlying PDO connection uses emul...
CVE-2026-73699	New	8.6	HIGH		0.005		FileRun before 2026.3.0 contains a PHP object injection vulnerability that allows authenticated attackers to execute arbitrary code by exploiting incorrect options passed to unserialize() in the Perms::getPerms() method, where a positional array is used instead of the required named-key array to disable class instantiation. Attackers with database write access can inject a s...
CVE-2026-78302	New	8.6	HIGH		0.003		Joomla Extension - joomshaper.com - Unauthenticated Stored Cross-Site Scripting (XSS) via Unescaped Output in Views and Admin Lists in SP Property < 4.1.4 - Multiple template files across frontend views and administrator list tables rendered attributes and text values directly into HTML without contextual escaping.
CVE-2026-81213	New	8.6	HIGH		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to obtain sensitive information from internal network resources due to improper validation of user-supplied URLs.
CVE-2026-81789	New	8.6	HIGH		0.004		Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in Studio Wombat Advanced Product Fields Extended for WooCommerce allows Path Traversal. This issue affects Advanced Product Fields Extended for WooCommerce: from n/a through 3.1.6.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85217	New	8.6	HIGH		0.001		A maliciously crafted add-in, when installed and executed in Autodesk Fusion Desktop, can modify persistent network proxy settings without user notification or consent. A successful exploit may allow an attacker to redirect authenticated Fusion network traffic through an attacker-controlled proxy, potentially exposing sensitive information with the current user.
CVE-2026-87931	New	8.6	HIGH		0.004		A vulnerability has been found in Behavioral Technology Group Pavlok Behavioral Conditioning Wearable up to 20260707. Impacted is an unknown function of the component Apple Notification Center Service Event Handler. The manipulation leads to buffer overflow. The attack must be carried out from within the local network. The vendor was contacted early about this disclosure but...
CVE-2026-88056	New	8.6	HIGH		0.004	npm:@angular/platform-server	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular Server-Side Rendering in @angular/platform-server processes user-controlled resource or request URLs through HttpClient after application code validates them with WHATWG URL parsing. The resolveUrl ...
CVE-2026-88058	New	8.6	HIGH		0.005		Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes ProcessingInstruction DOM nodes inside fallback raw-content elements without escaping matching ancestor closing tags. ProcessingIns...
CVE-2026-88060	New	8.6	HIGH		0.007	npm:@angular/platform-server	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.30, 21.2.22, and 22.1.4, Angular server-side rendering (SSR) in @angular/platform-server serializes untrusted input inside template content nested in fallback raw-content elements such as noscript, iframe, noembed, and noframes. Th...
CVE-2026-88863	New	8.6	HIGH		0.002		capgo.app (npm package `capgo`) through version 12.207.1 does not compare the caller's role rank against the requested role in the validateInvite() function of supabase/functions/_backend/private/invite_new_user_to_org.ts. The POST /private/invite_new_user_to_org endpoint only requires the org.update_user_roles permission for org_super_admin invitations, so an authenticated ...
CVE-2026-88880	New	8.6	HIGH		0.004		Renovate before 44.11.3 fails to validate Link header destinations when following GitLab server pagination, allowing malicious servers to redirect credential-bearing requests. Attackers controlling a compromised GitLab server can specify a Link header pointing to attacker-controlled infrastructure to exfiltrate authentication credentials.
CVE-2026-88895	New	8.6	HIGH		0.004		CyberPanel before 3.0.5 fails to enforce two-factor authentication on API endpoints, allowing attackers to bypass TOTP requirements using password-derived tokens. Attackers who obtain an administrator's password can derive API tokens and perform administrative operations or create authenticated sessions without the second factor.
CVE-2026-11813	New	8.5	HIGH		0.001		A potential improper permissions vulnerability was reported in the Lenovo Filez Client application that could allow a local authenticated user to escalate privileges.
CVE-2026-63427	New	8.5	HIGH		0.001		An authentication bypass vulnerability was discovered in Lenovo Software Fix that could allow a local authenticated user to perform arbitrary code execution with elevated privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80436	New	8.5	HIGH		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service by deleting arbitrary RabbitMQ queues or exchanges due to improper authorization.
CVE-2026-81207	New	8.5	HIGH		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 allows any authenticated tenant — with no project membership or role — fully controls scheme/host/port/path of an outbound fetch originating from a shared-infrastructure pod, and the WSDL body is reflected verbatim to the caller. The ds-canvas pod sits on the OpenShift overlay with reach to co-tenant services, in-cluster CP4D APIs,...
CVE-2026-81540	New	8.5	HIGH		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to overwrite ruleset files belonging to other tenants due to a path traversal vulnerability.
CVE-2026-84063	New	8.5	HIGH		0.004		BurgerEditor 3.2.0 through 3.4.0 contains an issue with unrestricted upload of file with dangerous type. If this vulnerability is exploited, an arbitrary file may be uploaded by an attacker who can log in to the product, potentially allowing arbitrary PHP code to be executed may be caused.
CVE-2026-88886	New	8.5	HIGH		0.002		Renovate is a dependency update automation tool. In versions before 44.14.7 (and in Mend Renovate CE/EE distributions before 15.4.0, and the mend-renovate-enterprise-edition Helm chart before 10.4.0), the manager/gradle-wrapper module does not escape the distributionUrl value read from a repository's gradle/wrapper/gradle-wrapper.properties file before invoking the Gradle Wr...
CVE-2026-88889	New	8.5	HIGH		0.006		Renovate before 44.14.7 contains a command injection vulnerability in the Maven Wrapper manager that allows attackers to execute arbitrary commands by specifying a malicious distributionType parameter in maven-wrapper.properties. Attackers can inject shell commands through unescaped distributionType values to achieve remote code execution when Renovate processes Maven Wrapp...
CVE-2026-89049	New	8.5	HIGH		0.004		A server-side request forgery issue due to improper validation of equivalent address representations in the port forwarding to remote hosts functionality in Amazon AWS Systems Manager Agent (SSM Agent) before 3.3.4851.0 on all platforms might allow an authenticated remote user to bypass the remote destination denylist and reach link-local endpoints, potentially obtaining the...
CVE-2026-18994	New	8.4	HIGH		0.001		A potential improper authorization vulnerability was reported in the Lenovo File Manager Android Application, distributed exclusively in the Chinese market, that could allow a local authenticated user to read or modify protected files within the application.
CVE-2026-19136	New	8.4	HIGH		0.009		A potential command injection vulnerability was reported in the Tianxi AI Agent PC Application, distributed exclusively in the Chinese market, that could allow operating system commands to be executed if a local user opens a specially crafted link that is handled by the application.
CVE-2026-4130	New	8.4	HIGH		0.001		There is a storage of sensitive information in cleartext vulnerability in NI SystemLink. This vulnerability may allow an attacker with local access to obtain sensitive information stored by the system in the clear. This vulnerability affects NI SystemLink and NI SystemLink Server versions prior to 2026 Q3.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-42805	New	8.4	HIGH		0.001		A stack-based buffer overflow vulnerability exists in the Bosch Sensortec BHI385 SensorAPI (C library) within the debug message parser function bhi385_parse_debug_message (located in bhi385_parse.c). The function parses FIFO events and extracts an 8-bit message length directly from the attacker-controlled event payload (callback_info->data_ptr[0]) without enforcing bound...
CVE-2026-88022	New	8.4	HIGH		0.003		Improper neutralization of special elements in data query logic in the MongoDB integration for Laravel can cause an array supplied to an explicit equality filter to be interpreted as a query condition rather than as a literal value. This affects the three-argument `where` method when the operator is `=` or `eq`, as well as the `find` and `delete` methods that use that code p...
CVE-2026-88890	New	8.4	HIGH		0.003		OpenPanel through commit cd24bb8 contains an SQL injection vulnerability in the analytics filter builder that fails to validate profile.* filter column identifiers before interpolating them into ClickHouse WHERE clauses. An authenticated attacker with project-scoped read or root export credentials can inject arbitrary ClickHouse SQL to bypass project isolation and read other...
CVE-2026-87090	New	8.3	HIGH		0.002		Consul and Consul Enterprise are vulnerable to an authorization bypass in the catalog node-write path that may allow an authenticated attacker to delete another node's catalog registration and take over its node identity. An attacker with a token granting node-write permission on any single node name may exploit this issue if they can obtain the node ID of a node they do not...
CVE-2026-88033	New	8.3	HIGH		0.003	mongodb:java_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Java Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the ...
CVE-2026-88883	New	8.3	HIGH		0.003		Renovate is an automated dependency update tool. In versions before 44.14.4 (and Mend Renovate CE/EE images before 15.4.0 and the mend-renovate-enterprise-edition Helm chart before 10.4.0), log sanitisation for TLS private keys used for Mutual TLS was incomplete. While the value of hostRules[].httpsPrivateKey was redacted in the field itself, the same private key value was n...
CVE-2026-88009	New	8.2	HIGH		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. Prior to 2.11.57, and 3.7.13, Traefik accepts a rootless HTTP/1 request target that Go stores in URL.Opaque while leaving URL.Path empty. The rewriteRequestBuilder path evaluates routing, path sanitization, forwardAuth, encodedCharacters, and access logging against a path normalized to / but forwards URL.Opaque ...
CVE-2026-88879	New	8.2	HIGH		0.002	traefik:traefik	Traefik is an HTTP reverse proxy and load balancer. In Traefik v1.x, v2.x through v2.11.55, and v3.0.0 through v3.7.11, header names are canonicalized only on dashes, so X-Auth-User, X_Auth_User and X.Auth.User are treated as three distinct headers by Traefik, while backends that derive variable names from header names (CGI, WSGI, PHP, NGINX and others) collapse them into a ...
CVE-2026-88897	New	8.2	HIGH		0.003		Flextype CMS through 1.0.0-alpha.3 accepts API authentication credentials through URL query string parameters in REST API routes. Attackers with access to web server, proxy, or monitoring logs can recover valid API token pairs that grant full API access.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89054	New	8.2	HIGH		0.004		A missing authorization vulnerability in OpenNMS Horizon allows configuration changes without authentication. The Spring Security policy for the /api/v2 REST API defines authorization rules for every HTTP method except PATCH, so the shipped @PATCH configuration endpoints for event configuration and SNMP data collection (which enable and disable event definitions and data-col...
CVE-2026-80354	New	8.1	HIGH		0.003	apache:camel	Authorization bypass through User-Controlled key vulnerability in Apache Camel K. An authorization vulnerability in custom resource resolution allows a tenant to reference secrets by name in the operator namespace, potentially exposing secrets belonging to other tenants or operator components. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 befo...
CVE-2026-81268	New	8.1	HIGH		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to execute flows and obtain sensitive information due to insufficient session expiration of API keys after user deactivation.
CVE-2026-81551	New	8.1	HIGH		0.005	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to arbitrarily write to or delete files on shared storage due to a path traversal vulnerability.
CVE-2026-81784	New	8.1	HIGH		0.003		Unauthenticated PHP Object Injection in Wise Chat <= 3.4 versions.
CVE-2026-81801	New	8.1	HIGH		0.003		Subscriber Settings Change in WP-Stateless <= 4.4.1 versions.
CVE-2026-81805	New	8.1	HIGH		0.002		Unauthenticated Privilege Escalation in SiteSkite <= 2.1.5 versions.
CVE-2026-82925	New	8.1	HIGH		0.003		The Site Reviews WordPress plugin before 8.3.0 does not prevent request data from being deserialized, and derives the key protecting that data by padding out the site's WordPress nonce key, which makes the key publicly computable on installs where that key is absent, left at its sample value, or too short to be secret. This allows unauthenticated users to inject arbitrary PH...
CVE-2026-87958	New	8.1	HIGH		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-88011	New	8.1	HIGH		0.002	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. Prior to 2.11.56, and from 3.0.0 until 3.7.12, a client-supplied dot-form header such as X.Authenticated.User survives ForwardAuth replacement and underscoreHeadersStrategy because Go treats it as distinct from X-Authenticated-User while normalization-prone CGI, WSGI, PHP, and NGINX backends collapse both names....
CVE-2026-88865	New	8.1	HIGH		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate restream ownership in getRestream.json.php, allowing authenticated users with canStream permission to mint tokens for arbitrary restreams. Attackers can exchange the token to retrieve other users' stream keys from getLiveKey.json.php and publish to their YouTube, Twitch, or RTMP destinations.
CVE-2026-9327	New	8.1	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-14873	New	8.0	HIGH		0.002		The Bulk Password Reset plugin for WordPress is vulnerable to privilege escalation via account takeover in all versions up to, and including, 1.3.3. This is due to the plugin not properly validating a user's identity prior to updating their details like arbitrary user passwords, including administrator passwords, to a known plugin-configured custom value, enabling full accou...
CVE-2026-42807	New	8.0	HIGH		0.002		A heap-based buffer overflow vulnerability in the PC bridge protocol decoder of BoschSensortec COINES_SDK (versions 2.10 through 2.12.2) allows attackers to cause a denial of service (process crash) or potentially execute arbitrary code. The bridge decoder ({{bridge_decoder.c}}) trusts the packet length field provided by the external device and forwards it to the host re...
CVE-2026-2310	New	7.8	HIGH		0.003		IBM webMethods Integration Server 11.1 IBM webMethods Integration is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.
CVE-2026-79591	New	7.8	HIGH		0.001		A heap-buffer-overflow and use-after-free vulnerability exists in the xls_getCSS() function of libxls 1.6.3 due to insufficient validation of a file-controlled font index.
CVE-2026-84042	New	7.8	HIGH		0.001		A flaw was found in crun. When crun is built with libkrun and a container is started rootful with passt networking (krun.use_passt), crun can execute attacker-controlled payload from the container image with host root privileges. The issue is a regression in crun 1.29. It affects crun >= 1.29
CVE-2026-88047	New	7.8	HIGH		0.001	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, Classify::ReadNormProtos in src/classify/normmatch.cpp parses the NORMPROTO component of a .traineddata file and uses std::istream::operator>>(char*) to extract a whitespace-delimited token into a fixed 61-byte stack buffer without setting a stream width. The 100-byte line buffer can carry a token of up to...
CVE-2026-88051	New	7.8	HIGH		0.001	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, the callback form of GenericVector::read in src/ccutil/genericvector.h reads the independent int32 fields reserved and size_used_ from a .traineddata model without a cap or an invariant check. reserve(reserved) allocates the backing array, but the callback loop writes size_used_ elements. A crafted TESSDAT...
CVE-2026-88052	New	7.8	HIGH		0.001	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, UNICHARSET::load_via_fgets in src/ccutil/unicharset.cpp trusts the declared unichar count as a loop bound and uses id as an unchecked index into the unichars vector. unichar_insert_backwards_compatible can leave the vector unchanged for an empty, duplicate, or already-encodable representation, causing id t...
CVE-2026-88053	New	7.8	HIGH		0.001	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, Classify::ReadIntTemplates in src/classify/intproto.cpp reads NumClassPruners, NumClasses, and NumProtoSets from the TESSDATA_INTTEMP component of a crafted .traineddata file and uses those values as loop bounds without validating them against MAX_NUM_CLASS_PRUNERS, MAX_NUM_CLASSES, and MAX_NUM_PROTO_SETS....

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19584	New	7.7	HIGH		0.002		Velociraptor allows for the creation of notebook backups in its default enabled daily backup feature. When Velociraptor restores the backup, the notebook cell content is interpolated into a template with no ACL checks. This allows a malicious user with NOTEBOOK_EDITOR permission to plant a VQL query which will be evaluated at elevated permissions if the notebook's backup is ...
CVE-2026-81210	New	7.7	HIGH		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 concatenates three caller-supplied strings into a String.format path on the shared /ds-storage RWX PVC and returns the file with no project ACL — pure IDOR plus traversal. Read is constrained to files named job.log/error.log, but DataStage job logs routinely carry connection strings, {dsnextenc} ciphertexts (decryptable via d2-f023...
CVE-2026-87993	New	7.7	HIGH		0.003		The consul-template library is vulnerable to an information disclosure issue in its error handling path that may allow Vault secret values to appear in template error messages, log output, and downstream surfaces such as Nomad task events. This vulnerability (CVE-2026-87993) is fixed in consul-template 0.43.0.
CVE-2026-42804	New	7.6	HIGH		0.003		A stack-based buffer overflow vulnerability exists in the Bosch Sensortec BHI360 SensorAPI(C-Library) in versions up to and including commit d6b200416a. The vulnerability is located within the FIFO parsing and debug logging subsystem inside the function bhi360_parse_debug_message() in bhi360_parse.c (lines 1852-1875). The parser trusts the first payload byte of a debu...
CVE-2025-57231	New	7.5	HIGH		0.013		Path Traversal in avatar attachments in Docmost v0.21.0 allows an unauthenticated malicious actor to disclose local files via a POST Request in a public url.
CVE-2026-15019	New	7.5	HIGH		0.007		The Direct Download for WooCommerce plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 1.19 via the (top-level include) function. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. The product ownership check only verifies that some f...
CVE-2026-19436	New	7.5	HIGH		0.002		The Ultimate Gift Cards for WooCommerce WordPress plugin before 3.2.10 does not reconcile the value of the gift card coupon it issues against the amount actually collected at checkout, allowing unauthenticated users to obtain store credit worth more than they paid.
CVE-2026-19439	New	7.5	HIGH		0.003		The Ultimate Gift Cards for WooCommerce WordPress plugin before 3.2.10 does not have any authorisation check when displaying gift card details, allowing unauthenticated users to retrieve the gift cards attached to arbitrary orders and disclose customer personal data, balances, dates and, in 3.2.9, the live redemption code, which anyone holding it can spend. Versions from 3....
CVE-2026-45747	New	7.5	HIGH		0.003		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to version 7.0.16, the Lua TLS certificate information helper could dereference NULL certificate fields when a Lua script requested certificate information for TLS traffic where some certificate fields were absent. Crafted TLS traffic processed by a dep...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-45759	New	7.5	HIGH		0.006	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, Suricata could repeatedly perform expensive parsing of large HTTP `Content-Disposition` headers during HTTP response body processing. Crafted HTTP traffic could cause excessive CPU usage and denial of service. Versions 7.0....
CVE-2026-45762	New	7.5	HIGH		0.004		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, Suricata's IP defragmentation tracker lookup did not verify that an existing tracker used the same IP address family as the packet being processed. Under crafted fragmented IPv4/IPv6 traffic, an IPv6 fragment could be assoc...
CVE-2026-45765	New	7.5	HIGH		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, DNP3 reassembly could buffer data without sufficient parser-level bounds. Crafted DNP3 traffic may cause Suricata to consume excessive memory, potentially resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a ...
CVE-2026-45766	New	7.5	HIGH		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, certain NFS parser state structures were insufficiently bounded. Crafted NFS traffic may cause Suricata to consume excessive memory, potentially resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a ...
CVE-2026-45768	New	7.5	HIGH		0.005	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Starting in version 8.0.0 and prior to version 8.0.5, LDAP transaction state could store an unbounded number of responses. Because LDAP can be processed over UDP, crafted traffic may cause Suricata to consume excessive memory, potentially resulting in denial ...
CVE-2026-45769	New	7.5	HIGH		0.012	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, IKEv2 parser state could grow without bounds while storing client transforms. Repeated crafted UDP traffic may cause Suricata to consume excessive memory, potentially resulting in denial of service. Versions 7.0.16 and 8.0.5...
CVE-2026-45770	New	7.5	HIGH		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Starting in version 8.0.0 and prior to version 8.0.5, a Lua rule that registers too many flow variables can corrupt Lua detection state and may bypass Suricata's restricted Lua sandbox. This requires an affected Lua script/rule to be loaded. Excessive flow va...
CVE-2026-46387	New	7.5	HIGH		0.005		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, Suricata's HTTP/2 decompression path could grow the decompressed response-body buffer without an effective upper bound. A crafted HTTP/2 DATA payload using a high compression ratio, such as gzip, deflate, or brotli compress...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-49362	New	7.5	HIGH		0.006	apache:artemis	An unauthenticated remote attacker can create arbitrary durable queues via the CORE protocol, leading to unauthorized broker state manipulation and potential denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-49363	New	7.5	HIGH		0.005	apache:artemis	An unauthenticated remote attacker connecting with the CORE protocol can discover cluster node details by sending a SUBSCRIBE_TOPOLOGY request prior to authentication. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-6285	New	7.5	HIGH		0.003		Weak Password Recovery Mechanism for Forgotten Password vulnerability in Ankaref Innovation and Technology Inc. LIBRID/LIBREF allows Password Recovery Exploitation. This issue affects LIBRID/LIBREF: from 2.01.0.2183 through 10092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-71643	New	7.5	HIGH		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows an attacker to cause a denial of service via the EGOREplanFSM component
CVE-2026-71645	New	7.5	HIGH		0.004		An issue in Robotics-STAR-Lab (SYSU STAR Group) RACER Tested affected version: commit abcdef1234567890 allows an attacker to cause a denial of service via the exploration state machine
CVE-2026-71647	New	7.5	HIGH		0.004		An issue in EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows an attacker to cause a denial of service via the checkCollisionCallback, execFSMCallback, planFromGlobalTraj in ego_replan_fsm.cpp
CVE-2026-75584	New	7.5	HIGH		0.004		ION-DTN before 4.2.1-a.1 contains a denial of service vulnerability that allows unauthenticated remote attackers to crash the ION process by sending a BPv7 bundle with a zero-length payload. The canonicalizePayloadBlock() function in bpsec_util.c passes bundle->payload.length to zco_clone() without validating it against zero, causing a failed CHKZERO assertion that triggers ...
CVE-2026-77771	New	7.5	HIGH		0.002		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not scope its second-factor attempt limit to the account being attacked, keying it instead to an identifier the client supplies and can change at will, allowing an attacker who already knows a victim's password to make unlimited one-time-passcode guesses and defeat the second...
CVE-2026-79592	New	7.5	HIGH		0.003		An out-of-bounds read vulnerability exists in the xls_dumpSummary() function of libxls 1.6.3 due to insufficient validation of file-controlled OLE summary offsets.
CVE-2026-81265	New	7.5	HIGH		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5.
CVE-2026-81786	New	7.5	HIGH		0.002		Unauthenticated Broken Access Control in Thank You Page Customizer for WooCommerce <= 1.2.2 versions.
CVE-2026-81794	New	7.5	HIGH		0.002		Unauthenticated Broken Access Control in Shirt Product Designer for WooCommerce 1.0.4 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81799	New	7.5	HIGH		0.002		Unauthenticated Broken Access Control in Return Refund and Exchange For WooCommerce <= 4.6.4 versions.
CVE-2026-81803	New	7.5	HIGH		0.004		Subscriber Remote Code Execution (RCE) in RepairBuddy <= 4.1224 versions.
CVE-2026-81804	New	7.5	HIGH		0.002		Unauthenticated Sensitive Data Exposure in ZHBackup – Backup, Restore & Migration <= 2.4.2 versions.
CVE-2026-84821	New	7.5	HIGH		0.002		Unauthenticated Broken Access Control in WP Fast Total Search <= 1.82.284 versions.
CVE-2026-86093	New	7.5	HIGH		0.005	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-88032	New	7.5	HIGH		0.002	mongodb:java_driver	A use-after-free in the reactive client-side encryption component of the MongoDB Java Driver can cause native resources to be freed while an affected encrypted operation is still using them when the operation is cancelled. A party able to cause such an operation to be cancelled may cause the hosting application process to terminate. Reaching the issue requires an affected re...
CVE-2026-88045	New	7.5	HIGH		0.005	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.75.0 until 1.75.1, the serve S3 streamed multipart path in cmd/serve/s3/multipart.go passes attacker-controlled contentType to multipart.NewRW().Reserve before reading request-body bytes. waitTurn admits the current part and one oversized part when the bu...
CVE-2026-88286	New	7.5	HIGH		0.003		GeoVision GV-LPC2211 V1.13 improperly manages PTZ connection state, allowing an unauthenticated remote client to block the accept loop and prevent new PTZ connections.
CVE-2026-88287	New	7.5	HIGH		0.003		GeoVision GV-LPC2211 V1.13 fails to bound the number of Scopes tokens in unauthenticated ONVIF WS-Discovery Probe requests, allowing a remote attacker to corrupt stack control state and crash the discovery process.
CVE-2026-88289	New	7.5	HIGH		0.003		GeoVision GV-LPC2211 V1.14 (260903) fails to validate attacker-controlled variable-length fields before copying them into fixed-size stack buffers in multiple VLSVR request handlers, allowing an unauthenticated remote attacker to crash the VLSVR service.
CVE-2026-88290	New	7.5	HIGH		0.003		GeoVision GV-LPC2211 V1.14 (260903) allows unauthenticated clients to declare unbounded VLSVR frame lengths and indefinitely delay blocking receives, allowing remote exhaustion of memory, connection, and worker resources.
CVE-2026-9166	New	7.5	HIGH		0.003		Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in GIS Informatics GisLab Laboratory Management System allows Path Traversal. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.
CVE-2026-9336	New	7.5	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88004	New	7.4	HIGH		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 3.2.0 until 3.7.13, Traefik endpoint defenses aliasHeadersStrategy, underscoreHeadersStrategy, and forwardedHeaders inspect req.Header but not req.Trailer, allowing an unauthenticated client to submit an aliasing or trusted header name in an HTTP/1.1 chunked trailer or an HTTP/2 trailer. When the retry or...
CVE-2026-89043	New	7.4	HIGH		0.003		passport-saml-encrypted through 0.1.13 contains an XML signature wrapping vulnerability where signature verification and assertion extraction use independent XPath lookups with no cross-validation. Attackers holding any validly signed SAML message can prepend a forged unsigned assertion that gets accepted as the verified identity while the genuine signature validates against...
CVE-2026-81796	New	7.3	HIGH		0.002		Unauthenticated Broken Authentication in WP Travel <= 12.0.3 versions.
CVE-2026-88017	New	7.3	HIGH		0.002	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.64.0 until 1.75.1, the FTP auth-proxy driver in cmd/serve/ftp/ftp.go stores one obscured password per username in the server-wide userPass map[string]string instead of binding the credential or VFS to the authenticated session. If two accepted credentials use ...
CVE-2026-88888	New	7.3	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the Mix manager when processing private dependencies with unescaped organization parameters. Attackers can inject shell metacharacters through malicious package names to execute arbitrary commands as the Renovate user in binarySource=docker mode.
CVE-2026-89087	New	7.3	HIGH		0.002		The cstruct package before 6.3.0 for OCaml mishandles indexes.
CVE-2026-0310	New	7.2	HIGH		0.003		A buffer overflow vulnerability in the XML processing functionality of Palo Alto Networks PAN-OS® software enables an unauthenticated attacker with network access to the management web or dataplane interface to cause a denial of service (DoS) condition on VM-Series firewalls or execute arbitrary code with root privileges on the PA-Series firewalls. The security risk posed b...
CVE-2026-76562	New	7.2	HIGH		0.002		The Sidebar Manager Light plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'sbm_description' parameter in all versions up to, and including, 1.18 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inject...
CVE-2026-81431	New	7.2	HIGH		0.003		The Registration Form for WooCommerce WordPress plugin before 1.1.3 does not validate that the form referenced during registration is a legitimate registration form, reading the permitted-role allow-list from an arbitrary attacker-controlled post instead. A user able to create a post (Contributor and above) can therefore register a new account with an arbitrary role, includi...
CVE-2026-81468	New	7.2	HIGH		0.023	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Command execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88272	New	7.2	HIGH		0.003		GeoVision GV-LPC2211 V1.13 allows an administrator-controlled username containing shell metacharacters to be executed as arbitrary root commands when the stored username is later deleted.
CVE-2026-88273	New	7.2	HIGH		0.004		GeoVision GV-LPC2211 V1.13 allows an administrator-controlled PPPoE username to escape a sourced shell configuration assignment and execute arbitrary commands as root.
CVE-2026-88274	New	7.2	HIGH		0.004		GeoVision GV-LPC2211 V1.13 allows an administrator-controlled wireless SSID containing shell syntax to execute arbitrary commands as root.
CVE-2026-88275	New	7.2	HIGH		0.004		GeoVision GV-LPC2211 V1.13 allows an administrator-controlled WPA-PSK containing shell syntax to execute arbitrary commands as root when wireless configuration is applied.
CVE-2026-88276	New	7.2	HIGH		0.004		GeoVision GV-LPC2211 V1.13 allows administrator-controlled WEP key values containing shell syntax to execute arbitrary commands as root.
CVE-2026-88282	New	7.2	HIGH		0.003		GeoVision GV-LPC2211 V1.13 allows an administrator-controlled FTP username containing shell metacharacters to be executed as arbitrary root commands during a subsequent FTP-account update.
CVE-2026-88891	New	7.2	HIGH		0.003		OpenPanel fails to enforce read-only project access level on 26 of 29 mutating procedures, allowing read-level members to modify, delete, and publish project data. Attackers with explicit read-only access can delete reports and dashboards, schedule entire projects for deletion, publish private analytics to public share links, and modify alerting rules by exploiting missing a...
CVE-2026-78083	New	7.1	HIGH		0.002		Joomla Extension - joomshaper.com - Missing CSRF Token Verification in Property Booking and Agent Contact Endpoints in SP Property < 4.1.4 - The visitor booking (properties.booking) and agent contact form submission (agents.sendmail) endpoints processed POST requests without verifying Joomla session anti-CSRF tokens.
CVE-2026-80380	New	7.1	HIGH		0.001	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote attacker to perform unauthorized actions due to cross-site request forgery.
CVE-2026-81783	New	7.1	HIGH		0.002		Subscriber Broken Authentication in MailMunch – Grow your Email List <= 3.2.5 versions.
CVE-2026-81795	New	7.1	HIGH		0.002		Unauthenticated Cross Site Scripting (XSS) in Page Visits Counter – Lite <= 1.2.3 versions.
CVE-2026-84816	New	7.1	HIGH		0.001		Unauthenticated Cross Site Scripting (XSS) in WPCS <= 1.3.2 versions.
CVE-2026-84819	New	7.1	HIGH		0.001		Unauthenticated Cross Site Scripting (XSS) in WPAdverts <= 2.3.3 versions.
CVE-2026-85545	New	7.1	HIGH		0.002		There is an Vulnerability in some HikCentral Access Control versions. Authenticated low-privilege users can invoke API interfaces that their role is not authorized to access.
CVE-2026-87803	New	7.1	HIGH		0.002		An authorization bypass vulnerability exists in the Countly Server DBViewer due to flawed sub-pipeline detection in the aggregation stage sanitizer. The /o/db aggregation endpoint parses user-controlled aggregation JSON and passes it through a stage sanitizer that determines whether a nested array is a sub-pipeline by checking if every element contains a key present in a har...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87961	New	7.1	HIGH		0.003		ESP32-audioI2S versions 3.4.4 through 4.0.0 contain a heap-based out-of-bounds read vulnerability in the read_ID3_Header function due to a shadowed length parameter in ID3 synchronized-lyrics processing. Attackers can craft malicious MP3 files or HTTP audio streams with oversized frame size declarations to read past allocated buffer boundaries, causing device crashes or expo...
CVE-2026-88016	New	7.1	HIGH		0.002	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, when backend/local runs with --links, a source .rclonelink object can plant a symlink in the destination and later directory metadata is applied through that path. MkdirMetadata, writeMetadataToFile, and setTimes operate when Directory.translatedLink...
CVE-2026-88021	New	7.1	HIGH		0.002		Consul and Consul Enterprise are vulnerable to an authorization bypass in the Connect service mesh that may allow a service to reach a destination it is not authorized to access. When building Envoy RBAC rules to enforce Connect intentions, Consul did not correctly escape certain characters in service names, namespaces, and partitions, causing the generated authorization rul...
CVE-2026-88026	New	7.1	HIGH		0.002		Improper neutralization of regular-expression metacharacters in the LINQ query translation component of the MongoDB C# Driver can cause a caller-supplied character sequence to alter a regular-expression predicate generated by an affected application. An authenticated user who can influence such a value may cause the application to return records beyond those intended by the ...
CVE-2026-88027	New	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the embedded-document relation handling of the MongoDB integration for Laravel can cause a caller-supplied embedded record identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence such an identifier may delete all embedded documents in a ta...
CVE-2026-88028	New	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the polymorphic relation handling of the MongoDB integration for Laravel can cause a caller-supplied relation identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence a stored relation identifier may cause an affected application to return ...
CVE-2026-88048	New	7.1	HIGH		0.001	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, FullyConnected::DeSerialize in src/Istm/fullyconnected.cpp does not validate the deserialized layer scalars ni_ and no_ against the weight-matrix dimensions. During FullyConnected::Forward, MatrixDotVector in src/Istm/weightmatrix.cpp writes w.dim1() results into temp_line, which is sized from no_, and rea...
CVE-2026-88870	New	7.1	HIGH		0.001		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a cross-site request forgery vulnerability in the LoginControl plugin PGP key endpoints that lack CSRF token validation. Attackers can craft malicious pages with image tags pointing to savePublicKey.json.php to replace a logged-in victim's PGP 2FA public key, causing lockout or enabling account take...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88872	New	7.1	HIGH		0.002		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a cross-site request forgery vulnerability in the setPassword.json.php endpoint that allows unauthenticated attackers to modify any user's channel password by sending a GET request. Attackers can craft a malicious webpage that, when visited by an authenticated administrator, sets or clears any user's cha...
CVE-2026-88873	New	7.1	HIGH		0.001		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a cross-site request forgery vulnerability in view/logArchive.json.php that allows unauthenticated attackers to archive application logs by making GET requests without CSRF token validation. Attackers can craft malicious pages that trigger administrators' browsers to request the endpoint, copying se...
CVE-2026-88898	New	7.1	HIGH		0.002		AppFlowy-Cloud versions 0.7.2 through 0.9.64 fail to authorize callers against the workspace in the bulk publish endpoint path, allowing authenticated users to publish content into other tenants' namespaces. Attackers can write published views with attacker-controlled title, body and metadata into victim workspaces to deface public pages or host phishing content on trusted U...
CVE-2026-88915	New	7.1	HIGH		0.003		Affected versions of MISP do not consistently enforce the acting user's authorization when instantiating event templates. For templates using distribution = 4, the template can specify a sharing_group_id. The instantiation path passed that value into event creation without verifying that the user instantiating the template was actually permitted to use the selected sharing...
CVE-2026-88938	New	7.1	HIGH		0.003		knowns through 0.33.0 fails to confine the path argument of the code.find MCP tool to the project root, allowing AI agent sessions to read source files anywhere on the host. Attackers can supply absolute paths or relative traversal sequences to the path argument and retrieve full file contents from outside the intended project directory.
CVE-2026-89011	New	7.1	HIGH		0.003		isomorphic-git before 1.42.0 contains a prototype pollution vulnerability in the getRemoteInfo function that allows a malicious Git server operator to pollute Object.prototype by advertising crafted ref names containing '__proto__' path segments during ref negotiation. Attackers controlling a Git server can advertise a specially crafted ref such as '__proto__/_corsProxy' to r...
CVE-2026-9176	New	7.1	HIGH		0.001	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-15419	New	7.0	HIGH		0.002		In the silabser.sys driver for CP210x devices v11.5.0 and earlier, a local unprivileged user with a malicious device can use malformed packets to corrupt kernel pool memory, resulting in arbitrary code execution with escalated privileges.
CVE-2026-82079	New	7.0	HIGH		0.002		A stack-based buffer overflow vulnerability in the Nintendo Switch local wireless networking functionality may allow an attacker within wireless range to execute arbitrary code using return-oriented programming (ROP) through crafted network traffic. This issue affects Nintendo Switch: before 23.0.0.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88885	New	7.0	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the gomod manager when processing unescaped depName parameters in import-path update commands with binarySource=docker mode. Attackers can inject shell metacharacters through malicious dependency names to execute arbitrary commands as the Renovate user during Go module major version updates with postUpdate...
CVE-2026-88924	New	7.0	HIGH		0.002		A flaw was found in the admin backend of gvfs. The privileged gvfsd-admin daemon changes the ownership of newly created private D-Bus sockets by calling the link-following chown() function on a pathname inside a user-controlled directory. A local attacker can exploit this via a Time-of-Check Time-of-Use (TOCTOU) race condition and exchange the socket pathname with a symbolic...
CVE-2026-15417	New	6.9	MEDI		0.001		In the silabser.sys Windows 8 driver for CP210x devices, a local unprivileged user can use incorrect driver settings to cause a kernel crash.
CVE-2026-17038	New	6.9	MEDI		0.003		DrEryk Gabinet before 11.5.0 uses hard-coded API credentials in its ticket reporting component. These credentials can be used to authenticate directly to the ticket system API. This allows an attacker to perform privileged operations beyond what is offered by the application, including reading and modifying tickets.
CVE-2026-78084	New	6.9	MEDI		0.002		Joomla Extension - joomshaper.com - Missing Access Control in Gallery Image Management in SP Property < 4.1.4 - The gallery management controller tasks lacked authorization checks and CSRF token validation.. Users could invoke file removal actions with arbitrary path strings or upload unverified file types.
CVE-2026-78085	New	6.9	MEDI		0.004		Joomla Extension - joomshaper.com - Path Traversal in Gallery Image Management in SP Property < 4.1.4 - The gallery management controller tasks lacked directory confinement checks.
CVE-2026-78303	New	6.9	MEDI		0.003		Joomla Extension - joomshaper.com - Unvalidated Email Destination & Form Manipulation in Booking Requests in SP Property < 4.1.4 - Booking inquiries previously relied on client-submitted hidden fields for recipient routing, allowing potential email manipulation.
CVE-2026-78374	New	6.9	MEDI		0.003		Joomla Extension - joomlart.com - Open mail relay via contact AJAX endpoint in T4 Page Builder extension < 2.3.0 - The front-end JSON editor endpoint exposes an action called contact that requires no authentication, no CSRF token, no captcha (when no captcha plugin is enabled) and has no rate limiting. The attacker fully controls the recipient, subject and HTML body, and the...
CVE-2026-88878	New	6.9	MEDI		0.003	traefik:traefik	Traefik is an HTTP reverse proxy and load balancer. In versions >= v2.8.2 through <= v2.11.55 and >= v3.0.0 through <= v3.7.11, the entryPoints.<name>.transport.respondingTimeouts settings — notably readTimeout, which is enabled by default at 60s — are not applied to the HTTP/3 request path. readTimeout is enforced as a deadline on the underlying TCP connection, which cannot...
CVE-2026-88884	New	6.9	MEDI		0.002		Renovate is a dependency update automation tool. In versions before 44.3.1 (and Mend Renovate CE/EE images before 15.4.0, mend-renovate-ce Helm chart before 15.4.0, mend-renovate-enterprise-edition Helm chart before 10.4.0), digest updates are not subject to the internal `minimumReleaseAge` (stability age) checks. When a repository configures `minimumReleaseAge` and has depe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88896	New	6.9	MEDI		0.003		EspoCRM before 10.0.4 is vulnerable to server-side request forgery. HostCheck::ipAddressIsNotInternal(), which validates outbound URLs to block requests to internal/private IP addresses, strips ::ffff: (IPv4-mapped IPv6) prefixes but does not recognize IPv6 transition addresses that embed private IPv4 addresses: NAT64 (64:ff9b::), 6to4 (2002::), and Teredo (2001:0000::). An ...
CVE-2026-88940	New	6.9	MEDI		0.005		knowns through 0.33.0 fails to validate the path query parameter in the workspace browse endpoint, allowing remote attackers to enumerate arbitrary directories on the host filesystem. Attackers can traverse the directory structure to locate project directories and identify targets for further exploitation.
CVE-2026-42808	New	6.8	MEDI		0.002		An issue was discovered in Bosch Sensortec COINES_SDK versions 2.0 through 2.11. The host streaming API function {{coines_read_stream_sensor_data()}} fails to validate the boundaries of the caller-provided destination buffer. Internally, the stream processing mechanism in {{comm_intf_process_stream_response()}} discards the requested {{number_of_samples}} argument and...
CVE-2026-52097	New	6.8	MEDI		0.004		An issue in AppFlowy 0.11.8 allows a remote attacker to execute arbitrary code via the afLaunchUri, _afLaunchLocalUri (url_launcher.dart), OpenFilex.open, localPathRegex (common_patterns.dart) components
CVE-2026-81052	New	6.8	MEDI		0.001	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Download of Code Without Integrity Check vulnerability. An unauthenticated attacker with physical access could potentially exploit this vulnerability, leading to arbitrary code execution.
CVE-2026-81049	New	6.7	MEDI		0.001	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Missing Support for Integrity Check vulnerability. A high privileged attacker with local access could potentially exploit this vulnerability, leading to arbitrary code execution.
CVE-2026-81051	New	6.6	MEDI		0.002	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Security Version Number Mutable to Older Versions vulnerability. A low privileged attacker with physical access could potentially exploit this vulnerability, leading to Protection mechanism bypass.
CVE-2026-19840	New	6.5	MEDI		0.002		The Notiqoo WordPress plugin before 1.4.14 does not have capability checks on several of its AJAX actions and builds the name of the option to write from user input, allowing users with a role as low as contributor to modify arbitrary WordPress options, which can be used to deactivate Notiqoo WordPress plugin before 1.4.14 and to lock every administrator out of the site.
CVE-2026-54054	New	6.5	MEDI		0.003		Transmute is a free, open-source, self-hosted file conversion and compression tool. Prior to version 1.3.0, Transmute's URL import endpoint, `POST /api/files/url`, is vulnerable to Server-Side Request Forgery (SSRF). The HTTP downloader used by this endpoint fetches user-supplied URLs with redirects enabled and does not validate whether the target resolves to a public, exter...
CVE-2026-57822	New	6.5	MEDI		0.005	apache:artemis	When the broker is processing message-based management requests, sent by an authenticated messaging client that is authorized with MANAGE permission to perform management-via-messaging, the parameter processing can trigger Java deserialization of certain method parameters that the broker will not utilise. The permitted types allow to craft a payload causing excessive computa...
CVE-2026-66632	New	6.5	MEDI		0.002		Unauthenticated Content Injection in Simple Cloudflare Turnstile <= 1.42.1 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75880	New	6.5	MEDI		0.004	apache:artemis	An authenticated client could attach a consumer with a selector containing crafted wildcard usage that results in excessive evaluation during message delivery attempts, occupying a shared broker thread and leading to denial of service. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended t...
CVE-2026-78536	New	6.5	MEDI		0.003		Unauthenticated Broken Access Control in Robokassa payment gateway for Woocommerce <= 1.8.9 versions.
CVE-2026-79590	New	6.5	MEDI		0.003		A NULL pointer dereference vulnerability exists in the Prism parser component of mruby 4.0.0. An attacker can provide a specially crafted Ruby source file that triggers the parser to pass a NULL pointer to nonnull string handling functions, resulting in undefined behavior and application crash.
CVE-2026-79725	New	6.5	MEDI		0.003	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to read arbitrary files due to improper access control.
CVE-2026-80378	New	6.5	MEDI		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to improper authorization.
CVE-2026-81275	New	6.5	MEDI		0.004		Subscriber Arbitrary File Download in Youzify <= 1.3.7 versions.
CVE-2026-81554	New	6.5	MEDI		0.005	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-81782	New	6.5	MEDI		0.002		Subscriber Cross Site Scripting (XSS) in WP Docs <= 2.3.1 versions.
CVE-2026-81785	New	6.5	MEDI		0.002		Unauthenticated Broken Access Control in BuddyForms <= 2.9.0 versions.
CVE-2026-81787	New	6.5	MEDI		0.002		Unauthenticated Broken Authentication in IMPress for IDX Broker <= 3.3.0 versions.
CVE-2026-81791	New	6.5	MEDI		0.002		Subscriber Cross Site Scripting (XSS) in EventON <= 2.5.7 versions.
CVE-2026-81793	New	6.5	MEDI		0.002		Unauthenticated Broken Access Control in Salon booking system <= 10.31.5 versions.
CVE-2026-82092	New	6.5	MEDI		0.005	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an absolute-path traversal vulnerability.
CVE-2026-82100	New	6.5	MEDI		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to cause a denial of service due to a path traversal vulnerability.
CVE-2026-84828	New	6.5	MEDI		0.001		A flaw was found in PCS (Pacemaker Configuration System). A local attacker with membership in the 'haclient' group can exploit the 'pcs host auth --token' command to read the contents of arbitrary files on the filesystem, provided the files are shorter than 256 bytes. The file contents are read with root privileges by the pcsd daemon and can be exfiltrated by the attacker th...
CVE-2026-85310	New	6.5	MEDI		0.003		import_contacts Path Traversal in Groundhogg <= 4.7.1 versions.
CVE-2026-87106	New	6.5	MEDI		0.002		Consul and Consul Enterprise are vulnerable to a denial of service in the native RPC listener that may allow an authenticated client to exhaust server memory before ACL authorization is evaluated. A client that can complete the internal RPC mTLS handshake may exploit this issue without holding a valid ACL token. This vulnerability (CVE-2026-87106) is fixed in Consul 2.0.4 an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88005	New	6.5	MEDI		0.002	pip:open-webui	Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.8.0 until 0.9.0, Open WebUI's OAuth token exchange endpoint issues a session for a provider access token without applying the email domain allowlist that the normal OAuth login callback enforces. An account whose email domain the login callback would refuse could still obtain a worki...
CVE-2026-88006	New	6.5	MEDI		0.002	pip:open-webui	Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.8.0 until 0.11.1, Open WebUI's OAuth token exchange endpoint issues a session for a provider access token without running the OAuth role management that the normal OAuth login callback runs. A user whose provider roles the login callback would refuse, or would demote, could still obt...
CVE-2026-88268	New	6.5	MEDI		0.002		GeoVision GV-LPC2211 V1.13 contains an authenticated stack buffer overflow in SSVR fragment reassembly that allows a valid user to crash the SSVR service.
CVE-2026-88269	New	6.5	MEDI		0.002		GeoVision GV-LPC2211 V1.13 allows a Guest user to retrieve persistent device configuration containing plaintext administrative and user credentials through SSVR.
CVE-2026-88270	New	6.5	MEDI		0.002		GeoVision GV-LPC2211 V1.13 allows a Guest user to enter SSVR firmware-upgrade mode and disrupt live services before any firmware image is validated.
CVE-2026-88288	New	6.5	MEDI		0.004		GeoVision GV-LPC2211 V1.13 fails to restrict the filename supplied to BKDownloadLink.cgi, allowing a remote user with valid web credentials to read arbitrary files accessible to the root-run web service.
CVE-2026-88770	New	6.5	MEDI		0.002		A flaw was found in the Device Authorization Grant flow of Keycloak, an identity and access management solution. The issue occurs because the token redemption process fails to check if a user account is currently locked due to brute-force protection. If an attacker has an active session for a locked account, they can complete the device login process and receive new security...
CVE-2026-89044	New	6.5	MEDI		0.002	netty:netty	Netty versions 4.1.133.Final through 4.1.137.Final and 4.2.13.Final through 4.2.17.Final fail to properly validate the final transfer coding in the Transfer-Encoding header, allowing attackers to smuggle requests by using malformed encoding declarations. Attackers can split Transfer-Encoding headers across multiple lines or use values like 'chunked, xchunked' to bypass valid...
CVE-2026-89089	New	6.5	MEDI		0.002		A SQL injection vulnerability exists in the JasperReports-based reporting feature of multiple versions of OpenNMS Meridian and Horizon. A low-privileged authenticated user (ROLE_USER) can run the shipped, default-enabled online reports "Maintenance contracts expired" (AssetManagementMaintExpired) and "Maintenance contracts strategy" (AssetManagementMaintStrategy) via the rep...
CVE-2026-9225	New	6.5	MEDI		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an authenticated attacker to access sensitive files belonging to other users due to improper access control in the File/Read File component. When executing flows through the /api/v1/run/advanced/{flow_id} endpoint, the application allows component inputs to reference storage paths using arbitrary user or flow identif...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-15796	New	6.4	MEDI		0.002		The Builderall for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'bg_video_service_url' Setting in all versions up to, and including, 3.0.2 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts in pages that will...
CVE-2026-15820	New	6.4	MEDI		0.002		The Builderall for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Photo Module 'attributes' Setting in all versions up to, and including, 3.0.2 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts in pages that w...
CVE-2026-15889	New	6.4	MEDI		0.003		The Aruba HiSpeed Cache plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Post Content in all versions up to, and including, 3.0.14 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Contributor-level access and above, to inject arbitrary web scripts in pages that will execute whenever ...
CVE-2026-4657	New	6.4	MEDI		0.002		The Easy Google Fonts plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the control_selectors meta field in all versions up to, and including, 2.0.4. This is due to the plugin registering the control_selectors meta field with show_in_rest enabled but without a sanitize_callback, and subsequently outputting this unsanitized data directly into <style> tags ...
CVE-2026-5399	New	6.4	MEDI		0.003		The Redux Framework plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Slider field in User Profile settings in versions up to and including 4.5.13.1. This is due to insufficient input sanitization in the user_meta_save() function (which only sanitizes array values, not scalar values) and improper output escaping in the Redux_Slider::render() method, w...
CVE-2026-87870	New	6.4	MEDI		0.002		The Ninja Forms - Scheduled Exports plugin for WordPress is vulnerable to Stored Cross-Site Scripting via REST API Parameters (interval, format, emailTo) in all versions up to, and including, 3.0.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level privileges and above, to inject arbitrary web...
CVE-2026-81788	New	6.3	MEDI		0.002		Subscriber Broken Access Control in IMPress for IDX Broker <= 3.3.0 versions.
CVE-2026-88014	New	6.3	MEDI		0.001	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.72.0 until 1.75.1, the archive ZIP backend method (*Fs).readZip in backend/archive/zip/zip.go accepts archive/zip.FileName values from an untrusted central directory and exposes cleaned entry names without ensuring that they remain inside the archive namespac...
CVE-2026-88859	New	6.3	MEDI		0.003		A flaw was found in Evolution. A remote attacker can exploit this vulnerability by sending a specially crafted HTML email containing a spoofed vCard control. When a victim clicks on this control, Evolution's trusted JavaScript handler incorrectly assigns an attacker-controlled JavaScript URL to an iframe's source. This action leads to arbitrary JavaScript execution within th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88860	New	6.3	MEDI		0.002		Capgo fails to clean up channel permission overrides when a user's last organization role binding is deleted, leaving stale overrides active. Attackers can retain channel-specific permissions after their base RBAC access has been revoked to perform unauthorized actions like changing production OTA versions.
CVE-2026-85645	New	6.1	MEDI		0.002		The Form Maker by 10Web – Mobile-Friendly Drag & Drop Contact Form Builder plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the bulk_action parameter in all versions up to, and including, 1.15.46 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages tha...
CVE-2026-88023	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB PHP Library can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the ...
CVE-2026-88024	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Rust Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the ...
CVE-2026-88025	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C# Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the in...
CVE-2026-88029	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Python Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond th...
CVE-2026-88030	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Ruby Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the ...
CVE-2026-88031	New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Go Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may cause all GridFS file chunks in the affe...
CVE-2026-88034	New	6.1	MEDI		0.003	mongodb:c\+\\+_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C++ Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88036	New	6.1	MEDI		0.003	mongodb:c_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the int...
CVE-2026-16172	New	6.0	MEDI		0.001		Netskope was notified of an out-of-bounds heap read affecting the Endpoint DLP (EPDLP) service of the Netskope Client. A local standard user could potentially send a specially crafted message that is not properly validated with a bounds check, likely crashing the kernel driver handler. Successful exploitation could potentially crash the EPDLP service, temporarily interruptin...
CVE-2026-0307	New	5.9	MEDI		0.001		Multiple local privilege escalation vulnerabilities in the Palo Alto Networks GlobalProtect™ app allows a local user to escalate their privileges to NT AUTHORITY\SYSTEM on Windows and root on macOS and Linux. This enables a non-administrative user to execute arbitrary commands with administrative privileges. This GlobalProtect app on iOS, Android and ChromeOS is not impac...
CVE-2026-19596	New	5.9	MEDI		0.002		An XML External Entity (XXE) vulnerability exists in the XML collector of multiple versions of OpenNMS Meridian and Horizon. When OpenNMS collects XML from a source whose response is attacker-controlled (for example a compromised monitored host or an HTTP man-in-the-middle position), the collector's XML parser resolves external entities and external DTDs. This allows an atta...
CVE-2026-45751	New	5.9	MEDI		0.005		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, Suricata's inspection-buffer helper could leave an inspection pointer referencing freed memory after a chained transform caused the backing buffer to be reallocated. The issue is reached during a specific network traffic pr...
CVE-2026-45752	New	5.9	MEDI		0.005		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Starting in version 8.0.0 and prior to version 8.0.5, when certain detection transforms are chained, the decompress transform pipeline could read from an inspection buffer after it had been reallocated and freed. The issue is reached during network traffic pr...
CVE-2026-45763	New	5.9	MEDI		0.005		Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Starting in version 8.0.0 and prior to version 8.0.5, when Lua rule execution is enabled, the Lua sandbox memory limit was not consistently enforced for new allocations. Certain Lua allocation patterns could exceed `security.lua.max-bytes` without triggering ...
CVE-2026-49837	New	5.9	MEDI		0.003		GoBGP is an open source Border Gateway Protocol (BGP) implementation in the Go Programming Language. Versions prior to 4.6.0 contain a BGP OPEN capability parsing issue where several concrete capability decoders may parse data from the full remaining capability buffer instead of the slice bounded by the declared capability length, `CapLen`. A malformed BGP OPEN message can c...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-49838	New	5.9	MEDI		0.003		GoBGP is an open source Border Gateway Protocol (BGP) implementation in the Go Programming Language. Prior to version 4.7.0, GoBGP accepts a zero-length AS_PATH during UPDATE decoding and later panics while validating that attribute for a confederation eBGP peer. The vulnerable path is in the BGP UPDATE validator: a malformed UPDATE that should be rejected as a malformed AS_...
CVE-2026-68527	New	5.9	MEDI		0.003		Concrete CMS versions 8.3.0 through 9.5.2 are vulnerable to an authorization bypass in the Calendar event edit dialog (concrete/controllers/dialog/event/edit.php). The dialog checked permissions against the calendar identifier supplied in the request rather than the calendar owning the targeted event occurrence. A user with the "Add Event" permission on a single calendar cou...
CVE-2026-88763	New	5.9	MEDI		0.003		A flaw was found in the skupper-router component of Red Hat Service Interconnect, which is used to provide secure communication between distributed services. The issue occurs when the router processes a specially crafted network message using its AMQP field parser. Due to a lack of bounds on recursion during parsing, the router can run out of stack memory and crash, leading ...
CVE-2026-0306	New	5.8	MEDI		0.001		A vulnerability in the EndPoint Data Loss Prevention (DLP) enforcement of Palo Alto Networks Prisma® Access Agent enables a local user to bypass configured DLP policy enforcement controls and exfiltrate sensitive data. This Prisma Access Agent on macOS, Linux, iOS, Android and Chrome OS is not affected.
CVE-2026-88061	New	5.8	MEDI		0.002		career-ops is an open-source AI-assisted job search and application management tool. Prior to 0.8.0, the career-ops local web dashboard web/ exposed command-spawning and user-file-writing /api routes without validating request origin or restricting clients to loopback addresses. A malicious page in another browser tab could send cross-origin localhost requests while the dash...
CVE-2026-66674	New	5.6	MEDI		0.002		Unauthenticated Bypass Vulnerability in Simple Cloudflare Turnstile <= 1.42.1 versions.
CVE-2026-88264	New	5.6	MEDI		0.001		A flaw was found in crun. When the container configuration does not give /dev a dedicated mount, terminal setup can redirect /dev/console onto an attacker-controlled path, including via the read-only-rootfs bind-mount fallback. Affected versions are crun 1.29.1 and earlier. Default configurations that mount a fresh /dev are not exposed. No fixed release is available yet.
CVE-2026-88265	New	5.6	MEDI		0.001		A flaw was found in crun. After pivot_root, reopening /dev/null for stdio can follow a symlink and attach a host file to container stdio, then change that file's ownership. Affected versions are crun 1.29.1 and earlier. Default configurations that mount a fresh /dev are not exposed. No fixed release is available yet.
CVE-2026-87925	New	5.5	MEDI		0.003		A vulnerability was detected in Rizwan17 inventory-management-system up to bfe78a330d01bb26b9daec5dc9ecd5c77900e03f. This vulnerability affects the function storeCustomerOrderInvoice of the file includes/manage.php. Performing a manipulation of the argument pro_name[] results in sql injection. The attack can be initiated remotely. The exploit is now public and may be used. C...
CVE-2026-87933	New	5.5	MEDI		0.003		A vulnerability was found in DaveGamble cJSON up to 1.7.19. The affected element is the function cJSONUtils_MergePatch of the file cJSON_Utils.c. The manipulation results in use after free. The attack may be launched remotely. The exploit has been made public and could be used. The pull request to fix this issue awaits acceptance.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88035	New	5.5	MEDI		0.001	mongodb:c_driver	A size check in the client-side authentication path of the MongoDB C Driver can wrap around, so an unusually large user-name value is accepted and copied past the end of a small buffer. A party able to set the driver's connection settings may cause the application that embeds the driver to terminate unexpectedly. Reaching this code requires a build in which the optional exte...
CVE-2026-88049	New	5.5	MEDI		0.002	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, prior .traineddata hardening added bounds checks to NetworkIO::CopyTimeStepGeneral and NetworkIO::Randomize in src/lstm/networkio.cpp but left NetworkIO::WriteTimeStepPart and NetworkIO::AddTimeStepPart unchecked. In LSTM::Forward in src/lstm/lstm.cpp, source_ is sized from the independently deserialized n...
CVE-2026-88050	New	5.5	MEDI		0.002	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, RecodedCharID::DeSerialize in src/ccutil/unicharcompress.h validates length_ but accepts negative code_ values from a crafted .traineddata recoder component. UnicharCompress::ComputeCodeRange in src/ccutil/unicharcompress.cpp can consequently produce code_range_ equal to zero, after which SetupDecoder inde...
CVE-2026-88054	New	5.5	MEDI		0.002	tesseract-ocr:tesseract_ocr	Tesseract is an open source OCR engine. In version 5.5.3 and earlier, Plumbing::DeSerialize in src/lstm/plumbing.cpp rejects excessively large network stacks but accepts a zero-length stack for NT_SERIES, NT_PARALLEL, or NT_REVERSED layers in a crafted .traineddata model. During LSTMRecognizer initialization in src/lstm/lstmrecognizer.cpp, CacheXScaleFactor(XScaleFactor()) r...
CVE-2026-88055	New	5.5	MEDI		0.002		AnythingLLM is an application that turns pieces of content into context that any LLM can use as references during chatting. In 1.16.1 and earlier, the manager role can store meta_page_title or meta_page_favicon through /api/admin/system-preferences, and MetaGenerator inserts those values into production homepage HTML without escaping attribute values or text content. The val...
CVE-2022-26962	New	5.4	MEDI		0.002		Italtel NFV 11.1.2-20210318 allows Multiple Stored XSS under NP_BCCAS-RMCTRL-01 /IMCSCIWebGui/configuration.jsp?opration=list&object=announcementAS via the name, username, or mrfAnnouncementNameparameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the p...
CVE-2026-12682	New	5.4	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Ankaref Innovation and Technology Inc. LIBRID/LIBREF allows Stored XSS. This issue affects LIBRID/LIBREF: from 2.01.0.2183 through 10092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-12683	New	5.4	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Ankaref Innovation and Technology Inc. LIBRID/LIBREF allows Stored XSS. This issue affects LIBRID/LIBREF: from 2.01.0.2183 through 10092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-36392	New	5.4	MEDI		0.002		FairSketch Rise CRM Version 3.9.6 is vulnerable to Cross Site Scripting (XSS). An authenticated administrator can inject arbitrary JavaScript into an item's title, which is stored server-side and executed in the browser of any client user who visits the store page, enabling session hijacking, account takeover, and phishing.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87107	New	5.4	MEDI		0.002		Consul and Consul Enterprise are vulnerable to an authorization bypass in the catalog deregistration path that may allow a local ACL token to delete peer-imported catalog objects. A caller with {{service:write}} or {{node:write}} permission may exploit this issue to remove services, checks, or nodes imported from a peered cluster without holding authority over the peer origi...
CVE-2026-15461	New	5.3	MEDI		0.002		The Sierra Wireless HL78xx modem GNSS driver (drivers/modem/hl78xx/, later drivers/modem/vendor_standalone/hl78xx/) embeds a generic struct gnss_nmea0183_match_data match_data inside struct hl78xx_gnss_data. The generic NMEA0183 match helper (drivers/gnss/gnss_nmea0183_match.c) requires that context to be the first member because its callbacks cast user_data directly to stru...
CVE-2026-76653	New	5.3	MEDI		0.003		A missing authentication vulnerability in the VPN configuration management has been identified in Archer MR600 (v2, v3 & v5) and TL-MR6400 v8 due to improper access control; a remote unauthenticated attacker may be able to access and modify VPN configuration information without valid credentials. Successful exploitation may allow a remote unauthenticated attacker to...
CVE-2026-82582	New	5.3	MEDI		0.002		An authorization bypass vulnerability exists in SHIRASAGI through a user-controlled key, which may allow an unauthorized attacker to retrieve files from the groupware's shared file feature.
CVE-2026-84062	New	5.3	MEDI		0.003		BurgerEditor 3.0.0 through 3.4.0 contains an issue with authorization bypass through user-controlled key. If this vulnerability is exploited, the content of the page may be altered by an attacker who can log in to the product may be caused.
CVE-2026-84432	New	5.3	MEDI		0.002		Concrete CMS 9 through 9.5.2 did not validate an anti-CSRF token in the Boards custom slot dialog controller (concrete/controllers/dialog/board/custom_slot.php) saveTemplate() action. The action created a board_slot_proxy Block and dispatched an AddCustomSlotToBoardCommand against a board instance while gating only on the per-resource canEditBoardContents() permission, so a...
CVE-2026-88012	New	5.3	MEDI		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.8.2 until 2.11.56 and 3.7.12, HTTP/3 endpoints do not apply entryPoints..transport.respondingTimeouts.readTimeout because the timeout is enforced on a TCP connection and the HTTP/3 server has no corresponding QUIC stream deadline. An unauthenticated client can use a slow request body, trickling data ind...
CVE-2026-88015	New	5.3	MEDI		0.004	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, backend/local with --links or links=true exposes symlink targets as .rclonelink objects, and fs.RangeOption.Decode can pass an unchecked positive Range start through Object.Open and openTranslatedLink. The function slices the target string as linkdst...
CVE-2026-88046	New	5.3	MEDI		0.003	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone core does not reject parent-directory segments in source Object.Remote() values before fs/list, fs/walk, fs/sync, and fs/operations pass those values to destination backends. A flat-keyspace source object store populated with native non-rclone...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88057	New	5.3	MEDI		0.004	npm:@angular/compiler, npm:@angular/core	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.0, Angular's compiler and runtime in @angular/core and @angular/compiler could omit or select an incorrect sanitizer for security-sensitive directive host bindings because SecurityContext was derived from the ...
CVE-2026-88871	New	5.3	MEDI		0.001		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) contains a cross-site request forgery vulnerability in the CustomizeUser plugin's plugin/CustomizeUser/setSubscribers.json.php endpoint. The script reads users_id and ExtraSubscribers from \$_REQUEST and calls User::setExtraSubscribers() without requiring a POST request or a valid CSRF to...
CVE-2026-88892	New	5.3	MEDI		0.003		OpenPanel is an analytics platform. In all versions (no patched release available at time of publication), the data importer fetches a caller-supplied URL with plain fetch instead of the project's existing SSRF guard (apps/api/src/utlis/safe-fetch.ts). In packages/importer/src/providers/umami.ts, parseRemoteFile calls fetch() on config.fileUrl, which is validated only by z.s...
CVE-2026-88894	New	5.3	MEDI		0.002		Snipe-IT's predefined kit checkout path does not enforce Full Multiple Company Support (FMCS) tenant isolation on the checkout target. Unlike the single, bulk, API, accessory, license and consumable checkout paths, App\Services\PredefinedKitCheckoutService never calls \$item->canCheckoutTo(\$target); it only performs the actor-vs-item policy check and an availability check bef...
CVE-2026-9161	New	5.3	MEDI		0.002		Observable response discrepancy vulnerability in DernekPlus Website Template allows Account Footprinting. This issue affects Website Template: through 10092026. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-9338	New	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted request. A remote attacker could exploit this vulnerability to trigger excessive resource consumption, potentially leading to reduced availability of the affected service.
CVE-2026-9667	New	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2026-85544	New	5.2	MEDI		0.001		There is an Improper Encryption Configuration Vulnerability in some Hikvision Intercom Products. This could allow attackers to forge M1 cards.
CVE-2026-81635	New	5.1	MEDI		0.002		A cross-site scripting vulnerability exists in SHIRASAGI, which may allow an attacker to execute an arbitrary script in the web browser of a user who accesses a website using the affected product.
CVE-2026-87912	New	5.1	MEDI		0.002		A missing S3 bucket ownership verification in the AWS Security Agent plugin in Amazon aws-agents-for-devsecops before 1.1.0 might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87913	New	5.1	MEDI		0.002		A missing S3 bucket ownership verification in the AWS Security Agent MCP server before 0.2.0 version might allow remote attackers to obtain the private source archive of a scanned workspace, including credentials and infrastructure state contained in that archive, via a pre-registered storage bucket whose name is derived from a publicly known account identifier. To remedi...
CVE-2026-88921	New	5.1	MEDI		0.004		MISP contains an HTML injection vulnerability in the MISPElementHTMLFormatterTool component, which is responsible for rendering MISP element references (attributes, objects, and tags) into inline HTML during PDF report export via the convert_markdown_to_pdf module. The attribute(), objectAttribute(), object(), and tag() methods interpolated user-controlled fields (attribute ...
CVE-2026-89045	New	5.1	MEDI		0.001		zstd-jni versions 1.4.8-4 through 1.5.7-13 fail to validate negative length parameters in ZstdInputStreamNoFinalizer.read(), allowing attackers to trigger infinite loops. Attackers can pass negative length values to cause the read method to spin indefinitely while holding the stream monitor, blocking all other threads from accessing the stream.
CVE-2026-79723	New	5.0	MEDI		0.002	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote authenticated attacker to obtain sensitive information due to improper validation of user-controlled API endpoints.
CVE-2026-80434	New	5.0	MEDI		0.002	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to manipulate runtime caches and cause a denial of service due to an insecure direct object reference.
CVE-2026-18386	New	4.9	MEDI		0.007		The WP BackItUp Community Edition plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 2.1.0 via the 'backup_file' parameter parameter. This makes it possible for authenticated attackers, with administrator-level access and above, to read the contents of arbitrary files on the server, which can contain sensitive information. The bas...
CVE-2026-88279	New	4.9	MEDI		0.003		GeoVision GV-LPC2211 V1.13 copies oversized ONVIF CreateUsers username or password values into fixed stack fields, allowing an authenticated administrator to crash the ONVIF worker.
CVE-2026-88280	New	4.9	MEDI		0.003		GeoVision GV-LPC2211 V1.13 copies an oversized ONVIF SetUser password into a fixed stack field, allowing an authenticated administrator to crash the ONVIF worker.
CVE-2026-88281	New	4.9	MEDI		0.003		GeoVision GV-LPC2211 V1.13 fails to limit repeated Username elements in ONVIF DeleteUsers requests, allowing an authenticated administrator to overflow a stack array and crash the ONVIF worker.
CVE-2026-88283	New	4.9	MEDI		0.003		GeoVision GV-LPC2211 V1.13 fails to limit repeated User elements in ONVIF CreateUsers requests, allowing an authenticated administrator to overwrite stack control state and crash the ONVIF worker.
CVE-2026-88284	New	4.9	MEDI		0.003		GeoVision GV-LPC2211 V1.13 fails to limit repeated User elements in ONVIF SetUser requests, allowing an authenticated administrator to overwrite stack control state and crash the ONVIF worker.
CVE-2026-0304	New	4.8	MEDI		0.002		A privilege escalation vulnerability in Palo Alto Networks Cortex XDR Broker VM enables an authenticated low privileged user with man-in-the-middle (MitM) access to execute code with root privileges on the Broker VM.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76652	New	4.8	MEDI		0.005		An authenticated directory traversal vulnerability in file upload functionality has been identified in Archer MR600 (v2, v3 & v5) and TL-MR6400 v8. Due to insufficient validation of user-supplied file information, an authenticated remote attacker with access to the affected upload functionality could upload a specially crafted file and cause it to be written outside the inte...
CVE-2026-88038	New	4.8	MEDI		0.002		cookies is a Node.js library for reading and writing HTTP cookies, used by Koa via ctx.cookies. In versions before 0.9.2 the library validates the cookie name and value against character sets that reject the semicolon separator, but the domain and path options are checked only against a permissive RFC 7230 field-content matcher that allows semicolons, and both are written in...
CVE-2026-3096	New	4.7	MEDI		0.002		The product's web portals allow external links to be opened in a new browser tab. In certain configurations, the originating window retains access to the newly opened page, allowing interaction between the two browser contexts when navigating to external destinations. This vulnerability could allow an attacker to manipulate the original trusted application window after a us...
CVE-2026-49836	New	4.6	MEDI		0.002	pip:psd-tools	psd-tools is a Python package for working with Adobe Photoshop PSD files. Prior to version 1.17.1, `SmartObject.save()` writes an embedded smart object to a path taken verbatim from the PSD file. Because that name is attacker-controlled and unsanitised, a tool that extracts embedded objects from an untrusted `.psd` can be made to write attacker-chosen bytes to an attacker-ch...
CVE-2026-45767	New	4.4	MEDI		0.003	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a malicious rule could potentially overwrite any file on the file system on rule load or reload. Versions 7.0.16 and 8.0.5 fix the issue. Some workarounds are available. Preprocess `load`+ `save` rules to disallow absolute ...
CVE-2026-0305	New	4.3	MEDI		0.001		An information disclosure vulnerability in the Palo Alto Networks Prisma® Access Agent on Linux enables a local user to access sensitive configuration data and credentials. The Prisma Access Agent on macOS, Windows, iOS, Android and Chrome OS is not affected.
CVE-2026-15823	New	4.3	MEDI		0.002		The Builderall Cheetah For Wp plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the disable() function in versions up to, and including, 3.0.2. The wp_ajax_ba_cheetah_disable AJAX handler is registered without any capability or nonce verification, and the target post_id is sourced directly from user-controlled \$_POST...
CVE-2026-18594	New	4.3	MEDI		0.002		The Advanced Contact form 7 DB plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 2.1.3. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with custom-level access and above, to import forged CSV submission records into any Contact ...
CVE-2026-42806	New	4.3	MEDI		0.002		An out-of-bounds read vulnerability was discovered in the Bosch BME690 SensorAPI (C-driver) in version v1.0.3 and prior, specifically within the field data parsing logic in read_all_field_data (bme69x.c). The driver prefetches heater configuration registers into a contiguous 30-byte stack buffer (set_val) mapping IDAC, RES_HEAT, and GAS_WAIT tables. When parsing sensor...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85543	New	4.3	MEDI		0.002		Some Wi-Fi series camera products have insufficient permission validation on certain interfaces, allowing authenticated low-privileged users to obtain device Wi-Fi configuration information through these interfaces.
CVE-2026-86087	New	4.3	MEDI		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-88875	New	4.3	MEDI		0.002		AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) incompletely sanitizes sensitive user fields in the APIName=video response. Video rows include columns joined from the video owner's user record, and API::get_api_video() calls removeSensitiveUserFields() only when the caller is neither authenticated nor using a valid API secret; it never c...
CVE-2026-0309	New	4.0	MEDI		0.004		A command injection vulnerability in Palo Alto Networks PAN-OS® software enables an authenticated administrator to bypass system restrictions and run arbitrary commands as a root user. To be able to exploit this issue, the user must have access to the PAN-OS CLI and the device must be configured with a Luna Hardware Security Module (HSM). The security risk posed by this is...
CVE-2026-88059	New	4.0	MEDI		0.003	npm:@angular/common	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 20.3.28, 21.2.20, and 22.1.1, Angular's @angular/common HttpTransferCache can cache an authenticated response when Server-Side Rendering (SSR) and hydration use a hierarchical HttpClient configured with withRequestsMadeViaParent. The ch...
CVE-2026-88013	New	3.7	LOW		0.002	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.49.0 until 1.75.1, the HTTP backend attaches headers configured through --http-headers or headers= to requests in backend/http/http.go, while its fshttp.NewClient client follows redirects without a backend-specific http.Client.CheckRedirect policy. A configure...
CVE-2026-45761	New	3.3	LOW		0.001	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a crafted rule using mixed-case frame syntax could trigger a heap buffer overflow while Suricata is loading signatures. The issue is reached during rule parsing/loading rather than by network traffic alone. Versions 7.0.16 ...
CVE-2026-0303	New	2.4	LOW		0.001		A code execution vulnerability in Palo Alto Networks Checkov by Prisma® Cloud can allow arbitrary code execution when Checkov scans a directory that contains an attacker-controlled configuration file.
CVE-2026-15418	New	2.4	LOW		0.002		In the silabser.sys driver for CP210x devices v11.5.0 and earlier, a local unprivileged user with a malicious device can use malformed packets to leak up to 145 bytes of uninitialized kernel pool memory. This vulnerability affects Windows 10 and earlier.
CVE-2026-87926	New	2.1	LOW		0.003		A flaw has been found in Rizwan17 inventory-management-system up to bfe78a330d01bb26b9daec5dc9ecd5c77900e03f. This issue affects some unknown processing of the file index.php of the component Login Page. Executing a manipulation of the argument msg can lead to cross site scripting. The attack can be launched remotely. The exploit has been published and may be used. This prod...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-0302	New	1.1	LOW		0.008		An OS command injection vulnerability in Palo Alto Networks Checkov by Prisma® Cloud enables a local user to execute arbitrary commands in the processes running Checkov.
CVE-2026-0308	New	1.1	LOW		0.003		A stored cross-site scripting (XSS) vulnerability in Palo Alto Networks PAN-OS® software enables a malicious authenticated administrator to store or execute a JavaScript payload using the web interface. This issue is applicable to PAN-OS software on PA-Series and VM-Series firewalls and on Panorama (virtual and M-Series). Cloud NGFW and Prisma® Access are not affected by...
CVE-2026-88790	New	0.9	LOW		0.002		A security vulnerability has been detected in proma-ai Proma up to 0.19.37. Affected is the function resolveTargetPath of the file apps/electron/src/main/lib/file-preview-service.ts of the component File Preview Service. Such manipulation of the argument file_path leads to path traversal. Local access is required to approach this attack. The exploit has been disclosed public...
CVE-2021-4118	New				0.01	PyPI:lightning	pytorch-lightning is vulnerable to Deserialization of Untrusted Data
CVE-2022-0845	New				0.01	PyPI:lightning	Code Injection in GitHub repository pytorchlightning/pytorch-lightning prior to 1.6.0.
CVE-2024-5452	New				0.268	PyPI:pytorch-lightning	A remote code execution (RCE) vulnerability exists in the lightning-ai/pytorch-lightning library version 2.2.1 due to improper handling of deserialized user input and mismanagement of dunder attributes by the `deepdiff` library. The library uses `deepdiff.Delta` objects to modify application state based on frontend actions. However, it is possible to bypass the intended rest...
CVE-2024-5980	New				0.013	PyPI:pytorch-lightning	A vulnerability in the /v1/runs API endpoint of lightning-ai/pytorch-lightning v2.2.4 allows attackers to exploit path traversal when extracting tar.gz files. When the LightningApp is running with the plugin_server, attackers can deploy malicious tar.gz plugins that embed arbitrary files with path traversal vulnerabilities. This can result in arbitrary files being written to...
CVE-2024-8019	New				0.011	PyPI:lightning	In lightning-ai/pytorch-lightning version 2.3.2, a vulnerability exists in the `LightningApp` when running on a Windows host. The vulnerability occurs at the `/api/v1/upload_file/` endpoint, allowing an attacker to write or overwrite arbitrary files by providing a crafted filename. This can lead to potential remote code execution (RCE) by overwriting critical files or placin...
CVE-2024-8020	New				0.006	PyPI:lightning	A vulnerability in lightning-ai/pytorch-lightning version 2.3.2 allows an attacker to cause a denial of service by sending an unexpected POST request to the `/api/v1/state` endpoint of `LightningApp`. This issue occurs due to improper handling of unexpected state values, which results in the server shutting down.
CVE-2026-11720	New				0.005	Go:github.com/googleapis/mcp-toolbox	MCP Toolbox HTTP tool path parameters allow traversal to unintended endpoints in github.com/googleapis/mcp-toolbox
CVE-2026-12210	New				0.002	PyPI:utcp-gql	### Summary The fix for CVE-2026-44661 (commit `5b16e43`) added the `ensure_secure_url()` / `is_secure_url()` helpers and wired them into the three HTTP-family plugins, but it did not reach the GraphQL or WebSocket plugins. The GraphQL plugin (`utcp-gql`) still uses the `startswith` prefix check that the fix explicitly replaced, so `http://127.0.0.1.attacker.example` and `h...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12570	New				0.001	PyPI:keras	A vulnerability in keras-team/keras versions < 3.15.0 allows for a denial of service (DoS) attack when loading malicious .keras model files via the keras.models.load_model() function. The H5IOStore.__getitem__ method in keras/src/saving/saving_lib.py does not validate the shape or size of datasets, leading to unbounded memory allocation. A specially crafted .keras file can e...
CVE-2026-12876	New					PyPI:nltk	`nltk.parse.RecursiveDescentParser` (and `SteppingRecursiveDescentParser`) enumerate parses top-down with no bound on the number of recursive steps. A small, crafted context-free grammar makes a short input consume unbounded CPU (and/or exhaust the Python recursion stack), pinning a process indefinitely — a denial of service. ## Proof of concept Both of the following hang ...
CVE-2026-15529	New				0.004	PyPI:pyod	A vulnerability was detected in yzhao062 pyod 3.5.0/3.5.1/3.5.2. Affected is the function pyod.utils.persistence.load of the file pyod/utils/persistence.py. Performing a manipulation of the argument path results in deserialization. The attack can be initiated remotely. The pull request to fix this issue requires some minor changes.
CVE-2026-15736	New				0.004	PyPI:snowflake-sqlalchemy	Snowflake SQLAlchemy versions prior to 1.11.0 contain several security vulnerabilities, including: Improper handling of user-supplied column identifiers in merge operations could allow SQL injection through attacker-controlled input keys. An attacker may be able to exploit this through request field names in a dynamic upsert endpoint, potentially enabling read access to data...
CVE-2026-15925	New				0.003	PyPI:snowflake-connector-python	Improper TLS hostname verification in Snowflake Connector for Python versions prior to 4.7.1 and 3.18.1 may have allowed a network-positioned attacker to bypass certificate hostname validation on HTTPS connections made by the connector. An attacker with on-path network access could exploit this by intercepting or redirecting network traffic and presenting a certificate signe...
CVE-2026-25782	New				0.004	Go:code.gitea.io/gitea	Gitea tracked-time deletion is not scoped to the requested issue in code.gitea.io/gitea
CVE-2026-26292	New				0.007	Go:code.gitea.io/gitea	Gitea LFS mirror operations bypass migration HTTP transport protections in code.gitea.io/gitea
CVE-2026-27660	New				0.005	Go:code.gitea.io/gitea	Gitea draft releases and attachments are exposed without write permission in code.gitea.io/gitea
CVE-2026-27779	New				0.006	Go:code.gitea.io/gitea	Gitea forwarded-proto validation allows canonical URL spoofing in code.gitea.io/gitea
CVE-2026-27780	New				0.006	Go:code.gitea.io/gitea	Gitea pre-receive hook scanner errors allow branch-protection bypass in code.gitea.io/gitea
CVE-2026-31221	New				0.004	PyPI:lightning	PyTorch-Lightning versions 2.6.0 and earlier contain an insecure deserialization vulnerability (CWE-502) in the checkpoint loading mechanism. The LightningModule.load_from_checkpoint() method, which is commonly used to load saved model states, internally calls torch.load() without setting the security-restrictive weights_only=True parameter. This default behavior allows the ...
CVE-2026-37004	New				0.005	PyPI:litellm	BerriAI litellm <=1.82.4 is vulnerable to Server-Side Template Injection (SSTI), which allows unauthenticated remote attackers to execute arbitrary OS commands via a crafted dotprompt_content parameter in the /prompts/test endpoint due to use of an unsandboxed jinja2.Environment.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-41608	New				0.006	PyPI:thrift	Improper Handling of Highly Compressed Data (Data Amplification) vulnerability in Apache Thrift Python bindings. This issue affects Apache Thrift: before 0.24.0. Users are recommended to upgrade to version 0.24.0, which fixes the issue.
CVE-2026-43871	New				0.006	PyPI:thrift	Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in Apache Thrift Python, Go, PHP and Java bindings.This issue affects Apache Thrift: before 0.24.0. Users are recommended to upgrade to version 0.24.0, which fixes the issue.
CVE-2026-44484	New				0.004	PyPI:lightning	# Security Advisory: Compromise of PyTorch Lightning PyPI Package Versions **Published:** 2026-04-30 **Last Updated:** 2026-05-12 **Github Advisory:** [CVE-2026-44484](https://github.com/advisories/GHSA-w37p-236h-pfx3) We have identified a security incident affecting certain versions of one of our PyPI packages. ## What happened We have determined that one or more ...
CVE-2026-45018	New				0.007	PyPI:chainlit	#### Am I affected? Only if your deployment sets `features.mcp.enabled = true` in `.chainlit/config.toml`. **MCP has been disabled by default since v2.7.0**, so most Chainlit deployments are not affected. No authentication is required: `/mcp` is reachable by any client that can open a session. #### Summary When MCP is enabled (`features.mcp.enabled = true`), the `POST /mcp` ...
CVE-2026-45019	New				0.003	PyPI:chainlit	#### Am I affected? Only if your deployment sets `features.mcp.enabled = true` in `.chainlit/config.toml`. **MCP has been disabled by default since v2.7.0**, so most Chainlit deployments are not affected. No authentication is required: `/mcp` is reachable by any client that can open a session. #### Summary When MCP is enabled (`features.mcp.enabled = true`), the `POST /mcp` ...
CVE-2026-45830	New				0.003	PyPI:chromadb	A lack of authorization validation in version 0.4.17 or later of the ChromaDB Python project allows any authenticated users to arbitrarily read, write, update, or delete data in any tenant's collection regardless of which tenant they belong to.
CVE-2026-45831	New				0.002	PyPI:chromadb	The SimpleRBACAuthorizationProvider authorization provider in versions 0.5.0 or later of the ChromaDB Python project evaluates whether a user holds a given permission but never checks which tenant, database, or collection that permission applies to allowing users to perform cross tenant actions.
CVE-2026-45833	New				0.003	PyPI:chromadb	A code injection vulnerability in version 0.4.17 or later of the ChromaDB Python project allows an authenticated attacker to run arbitrary code on the server by sending a malicious model repository and trust_remote_code set to true in the /api/v2/tenants/default_tenant/databases/default_database/collections/{collection_id} if they have the UPDATE_COLLECTION permission.
CVE-2026-48828	New				0.007	PyPI:apache-airflow	The Bulk Variables API in Apache Airflow called the redactor without passing the variable's key, so the key-based `should_hide_value_for_key` check (which triggers on secret-suffixed key names like `*_password` / `*_token` / `*_secret`) could not fire for JSON-decodable variable values. An authenticated UI/API user with bulk Variable read permission could retrieve plaintext ...
CVE-2026-49114	New				0.001	PyPI:onnx	#### Summary The `save_external_data` method seems to include multiple issues introducing a local TOCTOU vulnerability, an arbitrary file read/write on any system. It potentially includes a path validation bypass on Windows systems. Regarding the TOCTOU, an attacker seems to be able to overwrite victim's files via symlink following under the same privilege scope. The mention...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-50024	New				0.004	PyPI:githacker	## Summary GitHacker through 1.1.7 did not validate path segments parsed from attacker-controlled `.git/HEAD` before joining them onto its output directory. A malicious server could coerce GitHacker into reading arbitrary local files. Contents do not stream back wholesale, but the recovery loop turns any 40-character hex substring into an outbound HTTP `GET` — an existence ...
CVE-2026-53710	New				0.008	PyPI:mcp-contextforge-gateway	**Commit:** `f855e54d5b7bc1c91b977574a03b91eff6b86bb6` **Component:** `mcp-servers/python/python_sandbox_server/src/python_sandbox_server/server_fastmcp.py` ## Vulnerability RestrictedPython's sandbox in ContextForge's `python_sandbox_server` sub-project allows arbitrary Python execution via three compounding weaknesses: 1. Raw `getattr` is exposed in `safe_builtins`, byp...
CVE-2026-53951	New				0.003	PyPI:copier	# Copier: trust-prefix bypass via path traversal runs tasks unprompted ### Summary In copier `>= 9.5.0, <= 9.15.1`, the `trust` setting's prefix match (`copier/_settings.py`) compares the template URL against a trusted prefix with a raw `str.startswith` and **no path normalization**, while the URL *is* normalized when the template is actually fetched (`Path.resolve`) for ...
CVE-2026-53964	New					PyPI:document-merge-service	### Impact A remote code execution (RCE) via server-side template injection (SSTI) allows for user supplied code to be executed in the server's context where it is executed as the document-merge-server user with the UID 901 thus giving an attacker considerable control over the container. The vulnerability is limited to XLSX templates, were the `xltp` library uses a npn-sand...
CVE-2026-54338	New				0.003	PyPI:jupyterhub	### Impact Invalid input to login resulted in unbounded logging output. Only form-based Authenticators (the default PAM Authenticator, but not the more widely used OAuthenticator) are affected. ### Patches Upgrade to 5.5.0. ### Workarounds Use an Authenticator that doesn't use a login form, such as OAuthenticator.
CVE-2026-54421	New				0.003	PyPI:ironic	In OpenStack Ironic through 35.0.1, when applying a PATCH to update fields in volume properties the user is authorized for, Ironic can return unredacted sensitive information (such as iSCSI credentials). The PATCH outcome is a security issue; the POST outcome is not a security issue.
CVE-2026-54529	New				0.004	PyPI:sqladmin	## Summary `ModelView.sort_query()` uses the attacker-controlled `sortBy` list-view query parameter without checking it against the configured `column_sortable_list` allow-list. The value is resolved with `getattr(model, ...)` and fed into relationship joins and `order_by()`, so a request can sort by **any** column of the model — including ones hidden from `column_list` — a...
CVE-2026-54548	New				0.001	PyPI:kas	### Summary kas persistently disables SSH host key checking for the invoking user when internal SSH key setup is triggered via `SSH_PRIVATE_KEY` or `SSH_PRIVATE_KEY_FILE` and no user-specific SSH configuration file exists so far. When this path is used, kas creates `~/.ssh/config` with a global `Host *` rule containing `StrictHostKeyChecking no`. This was intended to ease ...
CVE-2026-54553	New				0.003	PyPI:starlette-admin	## Summary Affected versions of Starlette-Admin prior to 0.16.1 do not properly validate user-supplied sort and search parameters against the configured field allowlists. While the administrative UI restricts available fields based on field configuration, the backend accepts arbitrary field names supplied through API requests. An authenticated user can submit crafted reque...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54569	New				0.008	PyPI:senaite-core	### Summary An unauthenticated remote code execution vulnerability in the SENAITE JSON API allows any network-reachable attacker to execute arbitrary Python on the Zope worker process via a two-request anonymous chain. The `/@API/update` route is reachable to anonymous callers and runs `eval()` on attacker-controlled input before any permission check fires. This is a diff...
CVE-2026-54590	New				0.004	PyPI:asyncssh	**Incomplete fix for CVE-2026-45309 (GHSA-g794-3fmp-753h).** The 2.23.0 guard that sanitises the SSH username before `%u` substitution in `AuthorizedKeysFile` blocks `/`, `\'` and `..`, but does not block a leading `~` (or `\${ENV}`), both of which are re-introduced by later expansion and reach the file open — defeating the guard. **Affected:** asyncssh 2.23.0 and c...
CVE-2026-54591	New				0.005	PyPI:asyncssh	-- -- Product asyncssh (all versions through 2.23.0) Related CVE-2019-6111 (same class in OpenSSH) Fix AsyncSSH 2.23.1 A malicious SSH server can write arbitrary files on the asyncssh SCP client's filesystem by sending filenames containing `../` traversal sequences. The SCP receive path does not currently sanitize server-provided filenames. By ch...
CVE-2026-54622	New				0.002	PyPI:django-cms	### Summary The clipboard copy paths of the `copy_plugins` admin endpoint validate only the target (the user's own clipboard) and skip source-side authorization. A staff user can copy plugins out of a placeholder they have no permission on into their clipboard, then read the (secret) content. ### Details In `cms/admin/placeholderadmin.py`, `_copy_plugin_to_clipboa...
CVE-2026-54623	New				0.003	PyPI:django-cms	### Summary The `move_plugin` admin endpoint does not prevent a plugin from being reparented under itself or one of its own descendants. Doing so creates a cycle in the plugin tree, after which the recursive descendant/ancestor SQL queries loop without terminating, stalling the request worker. ### Details `move_plugin` (in `cms/admin/placeholderadmin.py`) accepts a `pl...
CVE-2026-54624	New				0.002	PyPI:django-cms	### Summary The structure-board endpoint (`render_object_structure`) renders a page's plugin structure without verifying that the requesting user is allowed to view the page. The edit and preview endpoints enforce this via `render_page()`, but the structure endpoint does not, allowing a low-privileged staff user to read the plugin structure of a view-restricted page. ### De...
CVE-2026-54625	New				0.001	PyPI:django-cms	### Summary The CMS page cache key ignores the request headers that plugins declare via `get_vary_cache_on()`. The header is added to the response `Vary` header, but the CMS's own cache key does not incorporate the header values, so the first visitor's variant is served to all subsequent visitors regardless of their header values. ### Details `_page_cache_key` (in `cms/cach...
CVE-2026-54757	New				0.002	PyPI:compliance-trestle	### Impact A Server-Side Template Injection (SSTI) vulnerability exists in multiple locations of trestle's Jinja2 rendering pipeline due to a systemic pattern: **untrusted data is re-parsed as Jinja2 template source code without sandboxing**. This advisory tracks the root cause across all affected code paths. The core anti-pattern is: treating runtime data (rendered output...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-54770	New				0.003	PyPI:webob	## Summary This is a third follow-up to **CVE-2024-42353 / GHSA-mg3v-6m49-jhp3** and **CVE-2026-44889 / GHSA-fh3h-vg37-cc95**. WebOb makes the `Location` header absolute when it serves a redirect. To stop a relative or protocol-relative target from redirecting users off-host, it checks the value for a URI scheme and for a leading `/`, then joins it against the request URI...
CVE-2026-55073	New				0.002	PyPI:weasyprint	## Summary `url_fetcher` is WeasyPrint's documented mechanism for restricting resource loading - applications use it to block `file://`, internal hosts, etc. when rendering untrusted input. Two `write_pdf()` channels ignore the document's `url_fetcher` and build a fresh default `URLFetcher()` instead. A restrictive fetcher set on `HTML()` is silently bypassed for: - **`xm`...
CVE-2026-55099	New				0.004	PyPI:icalendar	#### Summary `Component.__eq__` compares subcomponents in `O(2^n)` time relative to nesting depth. Because the parser accepts arbitrarily nested components, a sub-kilobyte `.ics` file is enough to make a single equality check run for minutes or hang indefinitely. Any application that compares parsed components (`==`, `!=`, `in`, `set/dict` membership, deduplication, test asser...
CVE-2026-55227	New				0.002	PyPI:weblate	#### Impact The several endpoints could leak object existence information to users who had no access to it by HTTP status code 403 instead of 404. #### Patches * https://github.com/WeblateOrg/weblate/pull/19971 #### References Thanks to Yaohui Wang for reporting this via GitHub.
CVE-2026-55228	New				0.002	PyPI:weblate	#### Impact The API did not properly handle project- and workspace-scoped teams and allowed setting invalid configurations, including granting access to projects the user has no access to. #### Patches * https://github.com/WeblateOrg/weblate/pull/19970 #### References Parts of this issue were independently reported by four reporters: * @H3xV0rT3x via GitHub * [imhego](htt...
CVE-2026-55235	New				0.002	PyPI:langgraph-api	## Summary In affected versions of `langgraph-api` (the LangGraph Server runtime), a run or cron could be created with a relative webhook target. When the server later delivers such a webhook, it routes the request back into the same application through an in-process loopback transport that the authentication middleware treats as internal and does not authenticate. As a res...
CVE-2026-55236	New				0.002	PyPI:langgraph-api	## Summary In affected versions of `langgraph-api` (the LangGraph Server runtime), the run-creation path authorized the assistant attached to a run using a different authorization event than the rest of the assistant-handling code paths. Direct assistant reads and cron creation dispatch the `assistants.read` authorization event; run creation dispatched `assistants.search` w...
CVE-2026-55244	New				0.002	PyPI:asteval	## Summary An attacker who can supply expressions to `asteval.Interpreter.eval()` can raise `SystemExit`, `KeyboardInterrupt`, `GeneratorExit`, or `BaseException` from inside the sandbox. These exceptions are subclasses of `BaseException` but not `Exception`, so they bypass the `except Exception:` safety net in both `run()` and `eval()`. The exception propagates verbatim to...
CVE-2026-55247	New				0.003	PyPI:plone-app-event	#### Impact By abusing the iCalendar import functionality, a logged-in editor could take the whole site offline, make the server reach into the internal network and read calendar files off disk (SSRF), and store XSS. #### Patches The problem has been patched in `plone.app.event`. * For Plone 6.2: upgrade to `plone.app.event` 6.0.1 * For Plone 6.1: upgrade to `plone.app.event`...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55248	New				0.003	PyPI:plone-app-portlets	### Impact By adding an RSS portlet, and giving this a link to a very large file, a member can cause a denial of service attack, because Plone will use lots of memory. The member could also use different urls to try to get information about the internal network and open port numbers (SSRF). A malicious RSS feed could cause stored XSS, when the url of a feed item is a javascr...
CVE-2026-55253	New				0.004	PyPI:langgraph-checkpoint-mongodb	# Executive Summary A NoSQL injection issue exists in the langgraph-checkpoint-mongodb and langgraph-store-mongodb libraries. MongoDBSaver.list() and MongoDBStore.search() methods accept a filter parameter that is incorporated into MongoDB queries without sufficient validation. Because MongoDB query operator keys (those prefixed with \$) are not rejected during filter constr...
CVE-2026-55419	New				0.003	PyPI:reachy-mini	## Summary The Reachy Mini daemon exposes the "/api/media/sounds/upload" endpoint without authentication and file validation mechanisms. An attacker can use this endpoint to upload malicious files into the file system that will propagate in future attacks. ## Compromise Chain: Unauthenticated to Full Root Access This issue is part of a full compromise chain allowing an ...
CVE-2026-55468	New				0.002	PyPI:wagtail	### Impact The internal Pages admin [API](https://docs.wagtail.org/en/stable/advanced_topics/api/index.html) incorrectly returns page fields without access control when they are declared in `api_fields`. A user with access to the Wagtail admin can use this API to fetch draft and live page fields' contents that are part of `api_fields` on the base page model (title, slug, s...
CVE-2026-55485	New				0.004	PyPI:piccolo-admin	## Summary `piccolo_admin` uses a helper called `superuser_validators` to gate access to the user and session tables for non-superusers. The helper rejects `PUT`, `PATCH`, `DELETE`, and `POST`, but **does not reject `GET`**. The `sessions` table stores live session tokens **in plaintext**, and the token column is not marked `secret=True`, so it is included in every `GET` r...
CVE-2026-55509	New				0.004	PyPI:wsgidav	### Summary The sample `MySQLBrowserProvider` builds its SQL queries by concatenating strings, and the record key from the request URL goes straight into the WHERE clause with no escaping. Any user who can reach a share backed by this provider can inject SQL through the URL. Since these read shares are commonly published without authentication, an anonymous attacker can rea...
CVE-2026-55520	New				0.004	PyPI:protego	### Problem description Protego constructs regular expressions to match URLs against `robots.txt` `Allow:` and `Disallow:` directives, see `protego._urlpattern._URLPattern._prepare_pattern_for_regex()`. Every `*` in the directive value is translated into a lazy `.*?` regex piece, thus a specially crafted directive value with many asterisks may produce a regex that freezes t...
CVE-2026-55522	New				0.002	PyPI:praisonai	## Summary PraisonAI's workflow include implementation implicitly imports and executes an included recipe's `tools.py` file even when the documented `tools.py` autoload opt-in is unset. This bypasses the hardening added for the prior automatic `tools.py` RCE advisory family. A workflow that includes an untrusted local recipe can execute arbitrary Python module-level code b...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55523	New				0.004	PyPI:prisonaiagents	## Summary `prisonaiagents.tools.web_crawl_tools.web_crawl()` validates the initial URL and blocks direct loopback/private destinations by default, but the default httpx fallback still uses `httpx.Client(follow_redirects=True)` and does not revalidate redirect targets. An attacker-controlled public URL can pass the initial host check, redirect to loopback/private/cloud me...
CVE-2026-55524	New				0.002	PyPI:prisonaiagents	The web_crawl tool performs its SSRF check only on the initial URL: it resolves the hostname once with socket.gethostbyname and rejects private/loopback/link-local results. It then passes the URL to a fetcher that uses httpx.Client(follow_redirects=True) - or urllib.request.urlopen when httpx is absent, which also follows redirects - and re-resolves the hostname at connect t...
CVE-2026-55525	New				0.003	PyPI:prisonaiagents	### Summary `web_crawl` (an exported, model-callable tool) validates only the INITIAL URL's resolved IP against a private/loopback blocklist, then fetches with `httpx.Client(follow_redirects=True)` and never re-validates redirect targets. An attacker who controls the agent's crawl target (a malicious task, or prompt injection inside any page the agent already crawls) suppl...
CVE-2026-55526	New				0.002	PyPI:prisonaiagents	### Summary `prisonaiagents/tools/spider_tools.py` contains an SSRF protection bypass. The function `_host_is_blocked()` validates URLs against a list of blocked IP literals and hostname aliases, but never performs DNS resolution. Any hostname that resolves to a private or loopback IP address — including public wildcard DNS services like `127.0.0.1.nip.io` — bypasses t...
CVE-2026-55527	New				0.003	PyPI:prisonaiagents	### Summary `prisonaiagents/memory/file_memory.py::FileMemory.__init__()` constructs all memory file paths by directly joining the `user_id` parameter to a base path: ``python self.user_path = self.base_path / user_id # LINE 145 — no sanitization `` No validation or normalization is applied to `user_id` before the path join. An attacker who can supply a `user_id` ...
CVE-2026-55528	New				0.003	PyPI:prisonaiagents	Researcher: Kai Aizen — SnailSploit (@SnailSploit), Adversarial & Offensive Security Research Target: https://github.com/MervinPraison/PraisonAI --- Package: `prisonaiagents` on PyPI Affected version (empirically tested): 1.6.48 Component: `prisonaiagents.server.AgentServer` (the bundled HTTP / SSE server) --- ## TL;DR `AgentServer.ServerConfig` ad...
CVE-2026-55529	New				0.001	PyPI:prisonai	### Summary PraisonAI's MCP HTTP Stream transport uses an unsafe prefix match when validating the `Origin` header. The default localhost allowlist includes origins such as `http://localhost`, and the validation accepts any origin that starts with an allowed value. As a result, an attacker-controlled origin such as `http://localhost.evil.example` passes the localhost origin...
CVE-2026-55530	New				0.001	PyPI:prisonaiagents	Target: PraisonAI (`MervinPraison/PraisonAI`) Affected component: `prisonaiagents/tools/ast_grep_tool.py` — `ast_grep_rewrite` Affected versions: master at `ce97667156a116c50b4a3d1aa21e09f048903fda`; reproduced against the current `prisonaiagents` PyPI release (`prisonaiagents` <= 1.6.52). ## Summary Tools in `prisonaiagents/tools/` that modify on-disk stat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55531	New				0.002	PyPI:prisonai	### Summary The PrisonAI MCP HTTP-stream server creates a new in-memory session on every initialize request and never removes it. The cleanup routine that would expire sessions (<code>_cleanup_sessions</code>) is defined but never called anywhere in the codebase, and the configured session TTL is never enforced. There is no cap on the number of sessions. Because initialize requires no ...
CVE-2026-55532	New				0.001	PyPI:prisonai	### Summary The PrisonAI MCP server exposes an HTTP-stream transport (prisonai mcp serve --transport http-stream) that binds to localhost and, by default, has no API key. Its only access control for browser-originated requests is an Origin allowlist, which the code implements as required by the MCP 2025-11-25 security guidance. The allowlist check uses a prefix match (req...
CVE-2026-55533	New				0.003	PyPI:prisonai	### Summary The PrisonAI Recipe HTTP server silently allows unauthenticated requests when <code>auth</code> is configured as <code>api-key</code> or <code>jwt</code> but the corresponding secret is missing. This creates an authentication fail-open condition. An operator can start the Recipe server with authentication enabled, including on a non-localhost interface, but the server still accepts unauthenti...
CVE-2026-55534	New				0.003	PyPI:prisonai	### Summary PrisonAI's <code>prisonai serve agents</code> command exposes <code>--api-key</code> as the documented authentication control for production/external deployments, but the configured key is not enforced on the public agent invocation compatibility endpoints. An operator can start the server with <code>--api-key</code> and bind it to <code>0.0.0.0</code> , but any network-reachable caller can s...
CVE-2026-55535	New				0.002	PyPI:prisonai	### Summary The <code>webhook_url</code> field in the Jobs API silently passes validation when DNS resolution fails (<code>socket.gaierror</code>), enabling DNS rebinding attacks. An attacker's domain can initially resolve to a public IP (passing validation) then switch to an internal IP before the server makes the HTTP request. ### Details The validator catches <code>socket.gaierror</code> and silently al...
CVE-2026-55536	New				0.003	PyPI:prisonai	### Summary <code>prisonai/browser/server.py</code> validates incoming WebSocket connections using a Chrome extension Origin check. The regex <code>chrome-extension://[a-z0-9]{32}</code> is applied with <code>re.match()</code> , which only anchors at the start of the string, not the end. Any Origin header with more than 32 alphanumeric characters after <code>chrome-extension://</code> — including non-alphanumeric...
CVE-2026-55537	New				0.002	PyPI:prisonai	### Summary <code>prisonai/jobs/models.py::JobSubmitRequest.validate_webhook_url()</code> validates webhook URLs by resolving the hostname and checking whether the IP is private. When DNS resolution fails (<code>socket.gaierror</code>), the validator silently passes the URL via <code>except socket.gaierror: pass</code> . Additionally, even when DNS succeeds at validation time, the webhook is fired much...
CVE-2026-55538	New				0.003	PyPI:prisonai	### Summary <code>prisonai serve agents</code> exposes HTTP routes that invoke registered agents. The CLI advertises <code>--api-key</code> with help text "API key for authentication", parses it, and forwards it into <code>ServeHandler</code> . But <code>_create_agents_app()</code> never reads <code>config["api_key"]</code> again and installs no auth dependency or middleware on its direct routes. The configured key is a no-o...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55539	New				0.004	PyPI:prisonai	### Summary PrisonAI's async **Jobs API** (the FastAPI service in `prisonai/jobs/`) installs its router with no authentication middleware, no router-level dependency, and no per-route auth check. Any caller who can reach the jobs server can submit agent jobs (executed against the operator's configured LLM credentials), list every job in the shared store, read other jobs' r...
CVE-2026-55540	New				0.003	PyPI:prisonai	### Summary PrisonAI's `prisonai.code` tool wrappers (exported as `CODE_TOOLS` for agents) expose a `workspace` setting that the module itself treats as a path-traversal **security boundary** — `read_file`, `write_file`, `apply_diff`, and `search_replace` explicitly call `is_path_within_directory()` and return <code>"... is outside the workspace"</code> on violations. That boundary is ...
CVE-2026-55541	New				0.003	PyPI:prisonai	## Summary `prisonai serve agents` and `prisonai serve unified` both accept <code>--api-key` for authentication. The flag is parsed but never wired into the FastAPI app — no middleware, no header check, nothing. The server runs wide open regardless of what key you set. Tested on 4.6.50 from PyPI. ## Affected versions - Confirmed on **4.6.50** (current PyPI, 2026-06-02) - Lik...</code>
CVE-2026-55546	New				0.004	PyPI:qwed-mcp	### Summary `verify_math_expression()` in `qwed-mcp` v0.2.0 passes attacker-controlled strings directly to SymPy's `parse_expr()` without restricting `global_dict` or validating the expression's AST. Because `parse_expr()` internally calls `eval()` and Python automatically injects the current module's `__builtins__` when no explicit restriction is set, an attacker can embed...
CVE-2026-55558	New				0.003	PyPI:aiosmtplib	## Impact When a connection is upgraded with STARTTLS, aiosmtplib reads the server's 220 go-ahead reply and immediately performs the TLS handshake without discarding any data still sitting in the receive buffer. Bytes the protocol read off the plaintext socket before the handshake survive across the plaintext→TLS boundary (the asyncio transport is swapped in place, so the p...
CVE-2026-55571	New				0.003	PyPI:djust	### Impact djust's `LiveViewConsumer` mounts a `LiveView` over a WebSocket. When a view is gated (`login_required` / `permission_required`, or an `on_mount` hook that returns a redirect) and the connecting user is not authorized, the consumer sent the client a <code>{"type":"navigate","to":...}` redirect frame and then `return`ed — **without closing the socket and without cleari...</code>
CVE-2026-55585	New				0.004	PyPI:qwed	### Summary The `qwed` package (version 5.1.1) passes attacker-controlled input directly to SymPy's `parse_expr()` function without a restricted namespace. Because `parse_expr()` internally calls Python's `eval()`, any authenticated tenant can execute arbitrary Python code inside the API server process. The attack requires only a standard user account, which is freely obtai...
CVE-2026-55618	New				0.003	PyPI:eml-parser	## Summary `eml_parser` performs certain validations on potential URL strings to discard bogus values. In versions prior to `3.0.2`, this validation was performed before unescaping any HTML entities that might occur in the string. This caused the library to wrongfully reject valid URLs that use HTML entities for the `:`, `/`, or `.` characters. These URLs would then not be ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55619	New				0.003	PyPI:eml-parser	### Summary `eml_parser` uses the `email.utils.getaddresses()` function from the CPython standard library to parse e-mail headers that contain e-mail addresses (such as `To`, `Cc`, `Bcc`, `From`, `Reply-To`, `Sender`, ...). When the input header contains a deeply nested CFWS (comment / folding white space) construct, the recursive descent parser in the standard library exha...
CVE-2026-55620	New				0.004	PyPI:eml-parser	### Summary `eml_parser` strips parenthesised CFWS comments from `Received:` headers using a regex-based fix-point loop. The loop has quadratic time complexity in the number of nested parens. A single `Received:` header containing 5,000 nested parens causes ~1.3 seconds of CPU saturation per parsed message; runtime quadruples per doubling of nesting depth. ### Impact This...
CVE-2026-55640	New				0.005	PyPI:nextcloud-mcp-server	## Summary The `POST /webhooks/nextcloud` endpoint has no authentication by default: `WEBHOOK_SECRET` defaults to `None` and is never required by startup validation. When unset, the receiver accepts any unauthenticated POST. The `user_id` is taken directly from the attacker-supplied payload and passed to Qdrant, allowing an unauthenticated attacker to delete or corrupt vecto...
CVE-2026-55830	New				0.004	PyPI:restrictedpython	### Impact RestrictedPython rewrites sensitive operations to go through guard hooks. Attribute access becomes `_getattr_(obj, name)`, item access becomes `_getitem_(obj, key)`, writes go through `_write_`, and print goes through `_print_`. The embedding application supplies these hooks to enforce its policy. Argument-name validation rejects these protected names for regula...
CVE-2026-56695	New				0.004	PyPI:openharness-ai	OpenHarness ohmo gateway /resume and /summary slash commands default remote_invocable to True, allowing admitted remote senders to enumerate and load arbitrary session snapshots by ID. Attackers can exploit this to access victim snapshots containing private prompts, credentials, tool output, and file paths via shared gateway channels.
CVE-2026-56696	New				0.004	PyPI:openharness-ai	OpenHarness /issue and /pr_comments slash commands lack remote_invocable=False protection, allowing remote channel senders to write attacker-controlled Markdown into project context files. Admitted remote attackers can inject malicious content into .openharness/issue.md and .openharness/pr_comments.md files, which are subsequently injected into runtime system prompts, persis...
CVE-2026-56743	New				0.002	Go:github.com/cilium/cilium	Cilium may unexpectedly allow ingress traffic from the local namespace when a Kubernetes NetworkPolicy is configured with an ipBlock match in github.com/cilium/cilium
CVE-2026-57844	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-58473	New				0.005	PyPI:cognee	Cognee before 1.2.0 contains an improper access control vulnerability that allows unauthenticated attackers to overwrite the global LLM provider configuration by self-registering an account and calling the settings endpoint, which performs no admin or superuser check. Attackers can redirect all LLM operations instance-wide to an attacker-controlled endpoint by exploiting the...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59161	New		HIGH		0.004	Go:github.com/xuri/excelize, Go:github.com/xuri/excelize/v2	# Streaming GetRows row-bound bypass causes attacker-controlled allocation ## Summary Excelize's prior row-bound fix for GHSA-h69g / CVE-2026-54063 protects the checked worksheet parser, but the streaming worksheet reader used by `Rows` and `GetRows` does not enforce the same `TotalRows` bound on the row `r` attribute. A small XLSX file can set a row number above Excelize'...
CVE-2026-59162	New		MODE		0.004	Go:github.com/xuri/excelize, Go:github.com/xuri/excelize/v2	# Negative shared-string index causes panic in GetCellValue and GetRows ## Summary Excelize parses shared-string cell values with `strconv.Atoi` and checks only the upper bound before indexing the shared string slice. If an XLSX file contains a shared-string cell with ` <v>-1</v>`, the parsed index is negative. The upper-bound check still passes (`len(sharedStrings) > -1`),...</v>
CVE-2026-59177	New					PyPI:esphome-device-builder	## Summary On the Home Assistant add-on, the dashboard serves a trusted ingress site that skips authentication because the supervisor authenticates the request upstream. That site was binding `0.0.0.0`. The add-on runs in host network mode for mDNS, so binding all interfaces also bound the host's LAN interface, and any device on the local network could reach `http://<ha-ip>...
CVE-2026-59832	New				0.005	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Authenticated path traversal in /snippets/ static handler (serveSnippets) leaks conf/conf.json secrets and siyuan.db in github.com/siyuan-note/siyuan/kernel
CVE-2026-59834	New				0.005	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: SQL Query in Block Search Exposes Hidden Published Document Content in github.com/siyuan-note/siyuan/kernel
CVE-2026-59960	New		HIGH		0.005	npm:@argos-ci/core	## CI Branch Name OS Command Injection in @argos-ci/core ### Summary `@argos-ci/core@6.2.0` passes attacker-controlled CI branch/ref strings directly into an `execSync()` template literal in `packages/core/src/ci-environment/git.ts:89`. When a CI project has `hasRemoteContentAccess: false`, the Argos upload flow calls `getMergeBaseCommitSha()`, which invokes `gitFetch()` w...
CVE-2026-59965	New		HIGH		0.003	npm:@jhb.software/payload-alt-text-plugin	## Alt Text Endpoint Authorization Bypass via Payload Local API `overrideAccess` Omission ### Summary `@jhb.software/payload-alt-text-plugin` v0.7.0 exposes custom Payload CMS endpoints (`POST /api/alt-text-plugin/generate` and `/bulk`) that call the Payload Local API (`findByID` and `update`) without setting `overrideAccess: false`. Because Payload's internal logic evalua...
CVE-2026-61539	New				0.007	PyPI:xinference	### Summary Xinference used Python's unsafe `eval()` function when parsing Llama3 tool-call output generated by a large language model. Because the model output can be influenced by attacker-controlled prompts sent to the chat completion API, a remote attacker can craft prompts that cause the model to return a Python expression. Xinference then evaluates that expression on ...
CVE-2026-61663	New				0.003	PyPI:django-cms	## Summary The django-cms frontend-editing structure endpoint `` GET /<lang>/admin/cms/placeholder/object/<content_type_id>/structure/<object_id>/ `` did not perform an object-level authorization check for **non-`PageContent`** objects. Any authenticated, active staff user could request the structure endpoint for a frontend-editable object (a model using `PlaceholderRel...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62240	New				0.005	PyPI:crewai-tools	CrewAI before 1.15.1 contains a server-side request forgery vulnerability in the <code>validate_url</code> function that performs one-shot DNS resolution and blocklist checks before returning the original URL unchanged. Attackers can bypass the security filter by supplying URLs that redirect to internal addresses or use DNS rebinding techniques to access internal services and cloud metad...
CVE-2026-62674	New				0.003	PyPI:omnigent	### Summary An authenticated user with edit access to their own session can overwrite a shared/template agent by uploading a full agent bundle through <code>PUT /sessions/{session_id}/agent`</code> . Shared/template agents are shown as not MCP-editable, but this upload path still accepts a replacement bundle. By adding a <code>`stdio`</code> MCP server to the shared agent, the attacker can cause fu...
CVE-2026-62675	New				0.004	PyPI:omnigent	### Summary An authenticated user can upload a crafted agent bundle that defines a server-side Python callable tool. The server validates the uploaded bundle, but it does not block dangerous <code>`callable:`</code> paths in untrusted user-provided agent configs. When the tool is invoked, the runner imports and executes that Python callable. A crafted bundle can point the tool at <code>`subp...</code>
CVE-2026-62676	New				0.003	PyPI:omnigent	**Reporter:** Aaron / Aeon — autonomous security agent (https://github.com/aaronjmars/aeon) **Project:** <code>`omnigent-ai/omnigent`</code> v0.1.0 (Databricks) — meta-harness running Claude Code / Codex / Pi "in check with policies and sandboxing" **Component:** <code>`omnigent/policies/builtins/_shell.py`</code> (shared parser) → consumed by <code>`policies/builtins/github.py`</code> (<code>`write_repos`</code> / <code>`write_branc...</code>
CVE-2026-62677	New				0.004	PyPI:omnigent	### Summary An authenticated, non-admin user can obtain **arbitrary host-filesystem read/write** (and host environment-secret disclosure) on an Omnigent **runner** by uploading an agent bundle whose <code>`os_env.cwd`</code> points outside any intended workspace (e.g. <code>`/`</code> or <code>`/home/<victim>`</code>). The <code>`cwd`</code> field is taken **verbatim** from the bundle with no validation, normalization, or bo...
CVE-2026-63003	New				0.002	PyPI:django-cms	## Impact The only authorization gate on the duplicate flow is <code>`PageAdmin.has_add_permission`</code> , which checks <code>`user_can_add_page(user, site)`</code> / <code>`user_can_add_subpage(...)`</code> — i.e. **may this user create a page at all** . Nothing checks the user's relationship to the page being copied: - <code>`cms/admin/forms.py`</code> — <code>`DuplicatePageForm.source = ModelChoiceField(queryset=Page.objects.a...</code>
CVE-2026-65607	New				0.006	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: path traversal via <code>/export/temp/`</code> short-circuit branch (incomplete fix for the export-disclosure hardening, GHSA-6865-qjcf-286f) in github.com/siyuan-note/siyuan/kernel
CVE-2026-66053	New				0.002	PyPI:thrift	Improper Validation of Certificate with Host Mismatch vulnerability in Apache Thrift Python bindings. This issue affects Apache Thrift: before 0.24.0. Users are recommended to upgrade to version 0.24.0, which fixes the issue. This replaces CVE-2026-41603
CVE-2026-66394	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Stored and reflected XSS in SiYuan through an SVG sanitizer bypass in github.com/siyuan-note/siyuan/kernel

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67322	New				0.003	PyPI:gitpython	### Summary `Repo.clone_from()` passes the caller-supplied remote URL through `Git.polish_url()`, which on every non-Cygwin platform calls `os.path.expandvars()` on the URL before handing it to `git clone`. An attacker who controls the URL argument — the documented use case for `clone_from()` in "import repository from URL" features of CI servers, git-hosting mirrors, and de...
CVE-2026-67323	New				0.01	PyPI:gitpython	## Summary GitPython already know that --upload-pack / --exec are command-exec vectors, they are denylist in git/remote.py:535 and check by Git.check_unsafe_options() (git/cmd.py:963), the thing is this check him he is only call from fetch, pull, push and clone_from, everything else who build a git argv from caller values just go through, no check, three examples ## Code a...
CVE-2026-67325	New				0.019	PyPI:gitpython	## Command injection via long-option prefix abbreviation bypassing `check_unsafe_options` (incomplete fix of CVE-2026-42215 / GHSA-rpm5-65cw-6hj4) **Component:** gitpython-developers/GitPython (PyPI: GitPython) **Affected:** all versions carrying the 3.1.47 blocklist fix, through current `main` (verified at commit `20c5e275`, `3.1.50-42`) **Reporter:** hackkim ### Summary ...
CVE-2026-67445	New				0.004	Go:github.com/axllent/mailpit	Mailpit: SMTP command parser buffers unbounded command lines before syntax rejection in github.com/axllent/mailpit
CVE-2026-67446	New				0.004	Go:github.com/axllent/mailpit	Mailpit: Thumbnail generation decodes unbounded image dimensions before scaling in github.com/axllent/mailpit
CVE-2026-68508	New				0.003	PyPI:hydra-core	## Summary `hydra.utils.instantiate()` resolves and calls Python objects from config. If an application passes untrusted config to `instantiate()`, an attacker who controls `_target_` and its arguments can cause arbitrary code execution in the consuming process. Hydra is not a network service. Exploitation requires a consuming application, library, or user workflow to load...
CVE-2026-68584	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Anonymous publish-password authentication bypass via getHeadingChildrenDOM / getHeading*Transaction / getBacklinkDoc (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-68585	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Cross-boundary metadata disclosure via getBlockInfo (publish mode): reader-reachable document title/root info for publish-forbidden docs; sibling getDocInfo is filtered in github.com/siyuan-note/siyuan/kernel
CVE-2026-68586	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Cross-boundary content disclosure via getBacklinkDoc/getBackmentionDoc (publish mode): reader-reachable rendered DOM of publish-forbidden docs; sibling list endpoints are filtered in github.com/siyuan-note/siyuan/kernel
CVE-2026-68587	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Full-content disclosure of publish-disabled documents via getHeading*Transaction endpoints (publish mode): reader-reachable rendered DOM with no publish-access check in github.com/siyuan-note/siyuan/kernel
CVE-2026-69083	New				0.004	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Unauthenticated SQL execution and REGEXP injection via fullTextSearchAssetContent (publish mode): reader-reachable raw SQL (method 2) and unescaped REGEXP (method 3) on read-write asset-content DB in github.com/siyuan-note/siyuan/kernel

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69084	New				0.011	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Unauthenticated arbitrary SQL execution via searchEmbedBlock (publish mode) : reader-reachable raw statement on read-write handle, cross-notebook read/write in github.com/siyuan-note/siyuan/kernel
CVE-2026-69086	New				0.004	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Path Traversal via unvalidated avID in RenderAttributeView/AV read endpoints : reader-reachable cross-scope attribute-view disclosure in github.com/siyuan-note/siyuan/kernel
CVE-2026-69112	New				0.001	PyPI:accelerate	Hugging Face Accelerate through 1.14.0 contains a path traversal vulnerability in load_checkpoint_in_model and load_checkpoint_and_dispatch functions that fail to sanitize weight_map entries from sharded checkpoint indexes. Attackers can supply relative paths with ../ sequences or absolute paths to read arbitrary files, or point shard entries at named pipes to cause indefini...
CVE-2026-71211	New				0.003	PyPI:mlflow	MLflow's AI Gateway accepts an auth_config.api_base value when creating a gateway secret (mlflow/server/handlers.py, _create_gateway_secret) with no validation of scheme, host, or IP range; the value is stored verbatim. The gateway proxy endpoint (mlflow/server/gateway_api.py, raw_proxy) subsequently issues an HTTP request to that stored api_base plus a caller-supplied path ...
CVE-2026-71428	New				0.003	PyPI:unstructured	### Summary Server-Side Request Forgery in `unstructured`. The `url=` argument of `partition()`, `partition_html()`, and `partition_md()` is fetched via `requests.get()` with no host validation. The response body is returned as `Element` text, so this is a **full-read SSRF** — attackers reach loopback admin APIs, internal HTTP services, and cloud metadata endpoints, and rea...
CVE-2026-71486	New				0.003	PyPI:vllm	## Summary The `/v1/completions/derender` and `/v1/chat/completions/derender` endpoints accept caller-supplied `GenerateResponse` objects and postprocess every nested `choices[*].token_ids` list directly. Unlike the normal render/generate path, derender does not enforce model context length, resolved `max_tokens`, `max_num_seqs`, choice-count, or response-size bounds before...
CVE-2026-71492	New				0.003	PyPI:banks	## Summary `DirectoryPromptRegistry.set()` interpolates the attacker-controllable `Prompt.name` into a `Path` expression with no canonicalization. An application that derives the prompt name from request data lets a caller write attacker-controlled bytes outside the configured registry directory. ## Details `src/banks/registries/directory.py:44` ```python prompt_file = p...
CVE-2026-71493	New				0.004	Go:github.com/infracost/infracost	Infracost: Arbitrary file read via config-template readFile symlink traversal in github.com/infracost/infracost
CVE-2026-71494	New				0.004	Go:github.com/infracost/infracost	Infracost: Terraform Cloud and registry token disclosure via unvalidated hostname in github.com/infracost/infracost
CVE-2026-71513	New				0.008	PyPI:nlTK	NLTK before 3.10.3 contains a remote code execution vulnerability in AllowlistUnpickler that validates only the pickle module string and not the global name, allowing attackers to resolve dotted names by attribute traversal to callables outside the allowlisted namespace. Attackers can craft untrusted transition-parser models that execute arbitrary commands when TransitionPar...
CVE-2026-71642	New				0.002		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows an attacker to cause a denial of service via the EGOREplanFSM::checkCollisionCallback()

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-72789	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: The publish-access gate treats encrypted notebooks as publicly accessible by default, allowing anonymous readers to retrieve fully decrypted document content while a notebook is unlocked in github.com/siyuan-note/siyuan/kernel
CVE-2026-72790	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Notebook name, document count, size and timestamps are returned for any notebook, including notebooks hidden from readers, by /api/notebook/getNotebookInfo in github.com/siyuan-note/siyuan/kernel
CVE-2026-72792	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Tag labels from password-protected documents are returned to readers who have not entered the password in github.com/siyuan-note/siyuan/kernel
CVE-2026-72793	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Non-administrator responses from /api/system/getConf omit three secrets that the configuration-export path explicitly strips, disclosing the session-cookie signing key and the OS username to anonymous readers in github.com/siyuan-note/siyuan/kernel
CVE-2026-72794	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: The session-cookie signing key (Conf.CookieKey) is returned to anonymous readers by /api/system/getConf in github.com/siyuan-note/siyuan/kernel
CVE-2026-72795	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Embedded (transclusion) block content is returned without publish-access filtering, leaking private and password-protected document content to anonymous readers in github.com/siyuan-note/siyuan/kernel
CVE-2026-72796	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Static-file routes bypass the publish-access controls enforced on the REST API, exposing templates, snippets and export artifacts to anonymous readers in github.com/siyuan-note/siyuan/kernel
CVE-2026-72797	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: getEncryptedNotebookStatus discloses names and current lock/unlock state of all encrypted notebooks to anonymous readers in github.com/siyuan-note/siyuan/kernel
CVE-2026-72798	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Publish-access filter on renderAttributeView leaves related-database content unfiltered and fails open on non-block first columns in github.com/siyuan-note/siyuan/kernel
CVE-2026-72799	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing publish-access filter on the HPath/path-resolution endpoints discloses the private document tree to anonymous readers in github.com/siyuan-note/siyuan/kernel
CVE-2026-72800	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing publish-access filter on getAttributeViewKeysByID discloses database column schema, plus two unscoped block-ID enumeration oracles (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-72801	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Encrypted-notebook key-derivation material and wrapped notebook keys disclosed to anonymous readers, enabling offline master-password cracking in github.com/siyuan-note/siyuan/kernel
CVE-2026-72802	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Absolute filesystem path and OS username disclosure via resolveAssetPath in github.com/siyuan-note/siyuan/kernel
CVE-2026-72803	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing publish-access filter on getBlockAttrs and batchGetBlockAttrs discloses block attributes (name, alias, memo, custom fields) of protected documents in github.com/siyuan-note/siyuan/kernel

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-72804	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Graph endpoints omit the publish-password tier: anonymous readers receive block-level content of password-protected documents in github.com/siyuan-note/siyuan/kernel
CVE-2026-72805	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing publish-access check on getBlockBreadcrumb, getRefText, and getBlockTreeInfos discloses content and metadata of protected/forbidden documents in github.com/siyuan-note/siyuan/kernel
CVE-2026-72806	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Password (protected) tier omitted in the attribute-view/database publish filter: Reader receives rows of protected documents without the password (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-72807	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Second-order SSTI to arbitrary SQL via attribute-view template column (queryBlocks): malicious imported package executes SQL on victim kernel in github.com/siyuan-note/siyuan/kernel
CVE-2026-72808	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing publish-access filter on getFileAnnotation discloses private PDF annotations of forbidden/protected documents (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-72809	New				0.002	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Localhost-trust admin bypass on auth-code-gated endpoints, with potential remote reachability via the fixed-port proxy in github.com/siyuan-note/siyuan/kernel
CVE-2026-72810	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Publish-boundary bypass via WebSocket broadcast: anonymous readers receive a live unfiltered feed of all edits including protected/forbidden documents (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-72811	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: SQL injection in backlink/mention search via unescaped stored and client input (publish mode): first-order (client keyword) and second-order (stored document title) breakout on read-write handle in github.com/siyuan-note/siyuan/kernel
CVE-2026-72812	New				0.003	Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Missing authorization on refreshBacklink allows anonymous readers to trigger persistent server-side writes and unauthenticated resource amplification (publish mode) in github.com/siyuan-note/siyuan/kernel
CVE-2026-72818	New				0.005	PyPI:nlk	The URLs regular expression in nltk/tokenize/casual.py, compiled into TweetTokenizer.WORD_RE and applied by TweetTokenizer.tokenize, contains a naked-domain branch whose domain-label prefix [a-z0-9]+(?:[.][a-z0-9]+)* is unbounded. Input consisting of many alternating label separators can be partitioned in exponentially many ways, and because the branch also requires a trailing
CVE-2026-72920	New				0.004	Go:github.com/seaweedfs/seaweedfs	SeaweedFS: Unauthenticated filer IAM gRPC service grants S3 administrative control in github.com/seaweedfs/seaweedfs
CVE-2026-72921	New				0.002	Go:github.com/seaweedfs/seaweedfs	SeaweedFS: Filer JWT allowed_prefixes literal prefix match allows cross-tenant access to sibling paths in github.com/seaweedfs/seaweedfs
CVE-2026-73087	New				0.003	Go:github.com/amir20/dozzle	Dozzle: SSRF guard bypass via IPv6 transition addresses (6to4/NAT64/Teredo) in webhook notification dispatcher in github.com/amir20/dozzle

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73228	New				0.004	PyPI:djangorestframework	## Summary While investigating Django REST Framework's request parsing behavior, I identified that DRF's high-level `request.data` parsing appears to bypass Django's configured `DATA_UPLOAD_MAX_MEMORY_SIZE` protection for `application/json` and `application/x-www-form-urlencoded` request bodies. In the tested configurations, Django correctly raises `RequestDataTooBig` when...
CVE-2026-73229	New				0.003	PyPI:djangorestframework	Summary AdminRenderer may disclose data that would normally be protected by GET permissions when rendering a 400 Bad Request response for an invalid write request. If a view allows POST (or another write method) but denies GET, an invalid request rendered through AdminRenderer can invoke the view's GET handler and include data from the GET representation in the generated H...
CVE-2026-73232	New				0.004	Go:github.com/ffuf/ffuf, Go:github.com/ffuf/ffuf/v2	ffuf denial of service (OOM) via HTTP response decompression bomb in github.com/ffuf/ffuf
CVE-2026-73262	New				0.002	PyPI:prowler	## Summary Prowler's HTML output formatter inserts `finding.resource_tags` into the generated report without HTML escaping. A cloud principal who can create or edit a resource tag in an account that is later scanned can store HTML or JavaScript in that tag. When another user opens the generated Prowler HTML report, the payload executes in the report page. ## Impact This i...
CVE-2026-73292	New				0.002	Go:github.com/semaphoreui/semaphore	Semaphore UI: CSRF vulnerability on password change endpoint - No CSRF token or password confirmation in github.com/semaphoreui/semaphore
CVE-2026-73293	New				0.005	Go:github.com/semaphoreui/semaphore	Semaphore UI: Manager-to-owner privilege escalation via custom-role slug collision in github.com/semaphoreui/semaphore
CVE-2026-73294	New				0.006	Go:github.com/semaphoreui/semaphore	Semaphore U: OS Command Injection in github.com/semaphoreui/semaphore
CVE-2026-73295	New				0.002	PyPI:mkdocs-material	### Impact Material for MkDocs 7.2.0 through 9.7.6 contains a DOM-based cross-site scripting vulnerability in the optional `search.suggest` feature. A crafted `q` URL parameter could execute JavaScript in the documentation site's origin after user interaction. ### Patches The issue is fixed in Material for MkDocs 9.7.7. Users should upgrade to 9.7.7 or later. ### Workaro...
CVE-2026-73555	New				0.003	PyPI:vllm	## Summary When the vLLM API receives a malformed request (e.g., invalid JSON or missing required fields), FastAPI raises a Pydantic `RequestValidationError`. The `validation_exception_handler` in `vllm/entrypoints/openai/server_utils.py` converts this exception to a string via `str(exc)`, which includes the internal file path and line number of the handler function. The ex...
CVE-2026-73556	New				0.003	PyPI:vllm	### Summary The fix for `GHSA-rwx-mrjm-wc2m` ("ReDoS via `structured_outputs.regex` compiled without timeout") wrapped the regex compile in the `**xgrammar**` and `**outlines**` backends with `compile_regex_with_timeout` (and, for outlines, `validate_regex_is_buildable`). The `**lm-format-enforcer**` backend was left unguarded: it compiles the attacker-supplied regex with no tim...
CVE-2026-73557	New				0.003	PyPI:vllm	## Executive Summary The follow-up protection for CVE-2025-62164 is incomplete at vLLM revision `26587f9519e22a5c4549ead7595ad9ca3229c4fd`. It wraps serialized prompt-embedding reconstruction and dense conversion in `torch.sparse.check_sparse_tensor_invariants()`, but PyTorch 2.11.0 implements that context with save/enable/restore operations over process-global state. Two p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73558	New				0.003	PyPI:vlm	### Summary An integer overflow in the act_and_mul_kernel kernel can cause the output of one user request to be incorporated into the response of another request within the same inference batch. Under certain conditions, the last request in a batch can receive a partial or complete copy of the first user's inference result, resulting in cross-user data leakage. ### Details...
CVE-2026-73560	New				0.003	PyPI:vlm	### Summary `vlm/transformers_utils/processors/mimo_v2_omni.py` — the multimodal processor for `MiMoV2OmniForCausalLM` — issues `requests.get(...)` directly on user-supplied image and audio URL strings and `Image.open(...)` on user-supplied local paths, without the SSRF / `allowed_local_media_path` checks that `vlm.multimodal.utils.MediaConnector` was hardened with in...
CVE-2026-73667	New				0.006	Go:github.com/openchoreo/openchoreo	OpenChoreo: Authenticated OS command injection via OpenChoreo Workflow Plane templates enables code execution in privileged pods in github.com/openchoreo/openchoreo
CVE-2026-73840	New				0.002	Go:github.com/openchoreo/openchoreo	OpenChoreo: Unauthenticated build/workflow trigger via git-provider confusion (webhook signature bypass) in github.com/openchoreo/openchoreo
CVE-2026-73841	New				0.005	Go:github.com/openchoreo/openchoreo	OpenChoreo: Cross-project command execution and wirelog view access via OpenChoreo openchoreo-api exec and wirelogs endpoints in github.com/openchoreo/openchoreo
CVE-2026-73842	New				0.002	Go:github.com/openchoreo/openchoreo	OpenChoreo: cluster-gateway internal proxy performs no caller authentication and is not read-only — data-plane Secret disclosure and arbitrary Kubernetes mutation in github.com/openchoreo/openchoreo
CVE-2026-73843	New				0.003	Go:github.com/openchoreo/openchoreo	OpenChoreo: Unauthenticated access to data-plane operations via OpenChoreo cluster-gateway management APIs in github.com/openchoreo/openchoreo
CVE-2026-75526	New				0.002	PyPI:django-cms	## Summary When plugin rendering fails in edit mode, django CMS renders a `cms-rendering-exception` block so editors can see that a placeholder could not be rendered. Older code built that block's heading by interpolating the exception message, placeholder/source strings, and the failing plugin's short description directly into an HTML string, then returned the placeholder ...
CVE-2026-75602	New				0.004	Go:github.com/OpenListTeam/OpenList, Go:github.com/OpenListTeam/OpenList/v3, Go:github.com/OpenListTeam/OpenList/v4	OpenList: Authenticated arbitrary file write via Content-Disposition path traversal in SimpleHttp offline-download tool in github.com/OpenListTeam/OpenList
CVE-2026-76098	New				0.003	PyPI:mistune	## Summary Mistune v3.3.2 is vulnerable to a Denial of Service (DoS) attack via uncontrolled recursion in the HTML rendering of deeply-nested emphasis tokens. By submitting Markdown containing approximately 1,000 consecutive asterisk characters, an attacker causes the Python process to crash with RecursionError. ## Details The InlineParser's _process_emphasis_delimiters() c...
CVE-2026-76217	New				0.004	PyPI:gitpython	## Summary `IndexFile.remove()` and `Head.checkout()` forward `**kwargs` into `git rm` and `git checkout` with no guard. Passing `--pathspec-from-file=<file>` together with `--pathspec-file-nul` makes Git treat the whole file as a single NUL-delimited pathspec, and the unmatched-pathspec error quotes it verbatim. GitPython surfaces that through `GitCommandError.stderr`,...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76218	New				0.007	PyPI:gitpython	## Summary `Repo.init()` forwards `**kwargs` verbatim to `git init` with no unsafe-option guard and no `allow_unsafe_options` parameter. `git init --template=<dir>` copies `<dir>/hooks/*` into the new repo's `.git/hooks`, so an attacker-controlled `template` kwarg plants a hook that executes on the next git operation → arbitrary code execution. `--template` is already recogn...
CVE-2026-76219	New				0.003	PyPI:gitpython	## Summary `IndexFile.from_tree`, `IndexFile.reset` (→ from_tree) and `IndexFile.merge_tree` append caller-influenced treeish strings positionally to `git read-tree` with no unsafe-option guard, no `allow_unsafe_options` parameter, and no `--separator`. `git read-tree --index-output=<file>` writes the resulting index to an arbitrary path, and last-occurrence-wins lets an in...
CVE-2026-76220	New				0.006	PyPI:gitpython	## Summary The `check_unsafe_options` guard can be bypassed on every guarded method (clone/clone_from, fetch/pull/push, ls_remote, iter_commits, blame, archive) by combining a single-character kwarg with `split_single_char_options=False`. The guard's candidate list omits the smuggled option, but `transform_kwarg` emits a JOINED `<n<value>` argv token that git parses as `--up...
CVE-2026-78679	New				0.002	PyPI:gitpython	## Summary `TagReference.create()` forwards a caller-influenced positional `reference` value into `git tag` without it ever being inspected by the unsafe-option guard, allowing an arbitrary file read (the file's contents are returned in-band as the annotated tag message). This is an incomplete-fix bypass of commit `3af0c251` (the fix for GHSA-3f7w-8rr8-f37f's tag instance). ...
CVE-2026-78680	New				0.001	PyPI:nltk	Two NLTK sites executed the Graphviz `dot` program by bare name, so process creation resolved it via the search path — and on Windows via the current working directory — rather than a validated absolute location. An attacker who can place a file named `dot` where resolution looks (the CWD on Windows, or a writable/relative entry such as `.` on `PATH`) has their binary execut...
CVE-2026-81723	New				0.002	PyPI:nltk	## Summary `XMLCorpusView._read_xml_fragment()` reads a corpus file in 1 KiB blocks, appending each block to a growing `fragment` string, then calls `_VALID_XML_RE.match(fragment)` on the full accumulated buffer every iteration. Because each iteration rescans the entire accumulated fragment, the total amount of work grows quadratically with input size. Commit `c9c332284` (...
CVE-2026-82397	New				0.004	PyPI:tornado	## Summary Tornado parses `application/x-www-form-urlencoded` bodies with `urlib.parse.parse_qs` and does not pass `max_num_fields`. A body made almost entirely of separators produces tens of millions of fields, and the parse happens on the event loop before the handler runs, so a single request stalls the whole server. ## Where it is `tornado/escape.py`, at HEAD `e53003...
CVE-2026-82398	New				0.003	PyPI:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes. This requires a call to `read_until_whitespace` with an input which does not have whitespace for a long time. ### Patches This has been fixed in [pypdf==6.15.0](https://github.com/py-pdf/pypdf/releases/tag/6.15.0). ### Workarounds If you cannot upgrade yet, consider applying th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84305	New				0.001	PyPI:sqlparse	### Summary When SQL is formatted with reindentation enabled, `ReindentFilter` repeatedly rebuilds prefixes of the current statement to calculate token offsets. An attacker who controls SQL sent to this opt-in formatting path can supply a parenthesized tuple list that remains just below the grouping-token cap. Thousands of offset calculations then traverse an expanding toke...
CVE-2026-84309	New				0.001	PyPI:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to an infinite loop. This requires a (usually writing) code path where `TreeObject.insert_child` is involved. ### Patches This has been fixed in [pypdf==6.16.0](https://github.com/py-pdf/pypdf/releases/tag/6.16.0). ### Workarounds If you cannot upgrade yet, consider applying the changes from ...
CVE-2026-84310	New				0.001	PyPI:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes and large memory consumption. This requires accessing the outlines of a document with either lots of entries or nested outlines with long re-used nesting paths. ### Patches This has been fixed in [pypdf==6.16.1](https://github.com/py-pdf/pypdf/releases/tag/6.16.1). ### Workaro...
CVE-2026-84311	New				0.001	PyPI:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes and large memory consumption. This requires extracting the text of a page with lots of XForm objects, where some of them might be re-used. ### Patches This has been fixed in [pypdf==6.16.1](https://github.com/py-pdf/pypdf/releases/tag/6.16.1). ### Workarounds If you cannot up...
CVE-2026-84366	New				0.002	PyPI:scrapy	### Problem Scrapy's `S3DownloadHandler` sends signed S3 requests over plaintext HTTP by default. A normal request like `s3://bucket/key` is converted into `http://bucket.s3.amazonaws.com/key` unless `request.meta["is_secure"]` is explicitly set. The generated request is then signed with configured AWS credentials, so AWS authorization material can be sent without TLS. Vu...
CVE-2026-84378	New				0.003	PyPI:httpx2	### Summary HTTPX2's Server-Sent Events (SSE) parser repeatedly copied and rescanned buffered text when a server split one unterminated line across many response chunks. The total work grows quadratically with the length of the line. An attacker-controlled or compromised SSE endpoint can exploit this behavior to consume excessive client CPU. ### Details Before version 2.1...
CVE-2026-84379	New				0.003	PyPI:httpx2	### Summary HTTPX2 serializes the per-file `Content-Type` and custom headers supplied through the `files=` tuple API directly into the `multipart/form-data` body without validating custom header names or values. An attacker who can influence upload metadata passed to HTTPX2 can use CR or LF characters to terminate a multipart part header and inject additional part headers o...
CVE-2026-84380	New				0.002	PyPI:httpx2	### Summary HTTPX2 can automatically add a `Content-Length` header to a request that already contains a caller-supplied `Transfer-Encoding` header. The resulting HTTP/1.1 request contains both framing headers, which can create an ambiguous message boundary and enable request smuggling or connection desynchronization when processed by intermediaries that disagree about which...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84381	New				0.001	PyPI:httpcore2	### Summary httpcore2 does not start TLS for `wss://` connections routed through a SOCKS5 proxy. The WebSocket opening handshake and all subsequent frames are sent in plaintext through the proxy path, despite the caller selecting the secure `wss` scheme. The transport flaw affects httpcore2 releases before `2.10.0`. HTTPX2 exposed this behavior through its public `Client.w...
CVE-2026-84382	New				0.004	PyPI:httpx2	### Summary When decoding a compressed response body (`gzip`, `deflate`, `br`, or `zstd`), HTTPX2 fully decompressed each network read before yielding content to the application. A small compressed input could therefore cause a large intermediate memory allocation, even when the application streamed the response to keep memory usage bounded. ### Details HTTPX2's default t...
CVE-2026-84452	New				0.009	PyPI:winml-cli	Case Description: MSRC Notes: Attachments: 1 file(s) attached (1 mp4) Summary: The vulnerability lies in the 'serve/cli_api.py' component of the 'winml-cli' project, which exposes all winml CLI commands over HTTP without authentication. Although it binds to localhost by default, it sets 'allow_origins' to a wildcard, allowing any website to interact with the endpoint. This,...
CVE-2026-86073	New		MODE		0.002	npm:n8n	## Impact The OAuth token endpoint bound an authorization code's first access token to the consented resource, but not its refresh token. Refreshing only checked that the requested resource was registered, not that it matched the original grant. An OAuth client approved for one workflow could refresh with a different workflow's URL and get a valid, unapproved token for it. ...
CVE-2026-86074	New		MODE		0.003	npm:n8n	## Impact Instance AI credential setup accepted a credential test/verification URL without checking it matched the workflow node's origin. Exfiltration required the user to actively inject an attacker-controlled URL into the setup flow. The patch derives the credential destination from the node's own URL and confines authenticated requests, redirects and probes to that orig...
CVE-2026-86075	New		HIGH		0.003	npm:n8n	## Impact The OAuth Dynamic Client Registration endpoints validated field sizes only for `redirect_uris`, leaving `client_name` and `grant_types` bounded by presence checks alone. An unauthenticated remote caller could submit arbitrarily large values in either field and have them persisted to the database. Repeated registration therefore grew persistent storage without limi...
CVE-2026-86076	New		HIGH		0.004	npm:n8n	## Impact The expression compiler's sanitizer resolved through a dynamically-scoped `this`, so a class field named `__sanitize` rebound it and reached the `Function` constructor. On the backend, any expression author could run code in the n8n process; in the editor preview, a member's expression could run as JavaScript in the session of whoever opened the workflow. The patc...
CVE-2026-86077	New		MODE		0.003	npm:n8n	## Impact The `/chat` WebSocket route resumed a paused execution from a resume token without checking that the node being resumed was a chat node. n8n hands that token to anonymous form submitters, so a party with no account could present it on the chat route and release an execution waiting at an approval gate, the control an author puts in front of an action considered to...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86078	New		MODE		0.003	npm:n8n	## Impact The Instance AI workflow summary built its result with get-or-create-then-nested-write idioms keyed by node names and connection keys taken from the stored workflow. Those are arbitrary strings: the restricted-name guard n8n shows in the editor is client-side and is bypassed by posting the workflow to the REST API directly. So a reserved key such as `__proto__` re...
CVE-2026-86079	New		MODE		0.003	npm:n8n	## Impact The Elasticsearch and ElasticSecurity nodes built REST endpoints by interpolating user-provided identifiers straight into the request path. A value containing path separators or dot segments changed which endpoint the request actually reached, so an operation intended for one document could hit another index or a cluster administration endpoint instead, under the ...
CVE-2026-86080	New		MODE		0.002	npm:n8n	## Impact The GitHub Trigger generated a signing secret when it registered a webhook and verified `X-Hub-Signature-256` on each delivery. When GitHub answered the create request with a 422 because a webhook for the URL already existed, the node adopted the remote hook but kept only its id and events, discarding the secret it had generated. Deliveries to that workflow's webh...
CVE-2026-86081	New		HIGH		0.003	npm:n8n	## Impact The Git node's clone operation matched the destination path against the default `N8N_BLOCK_FILE_PATTERNS` expression, which was written so that a crafted path caused catastrophic backtracking. Evaluation runs synchronously in the main n8n process, so an authenticated user could freeze the instance for everyone with a single workflow execution and no unusual config...
CVE-2026-86082	New		HIGH		0.002	npm:n8n	## Impact The OpenAI Chat Model node checked a custom base URL against the credential's allowed-domains configuration before sending a request, but the model-search dropdown did not. A request setting `options.baseURL` on that path reached an arbitrary host with the credential attached, so the domain restriction an administrator configured did not hold for every route the n...
CVE-2026-86083	New		HIGH		0.004	npm:n8n	## Impact Two stages of expression code generation built source text by calling the global `JSON.stringify` at generation time: the compiler when printing synthetic string literals, and the isolate bridge when interpolating a timezone value into its per-evaluation wrapper. An expression that replaced that global therefore changed the code that was subsequently generated and...
CVE-2026-86084	New		MODE		0.003	npm:n8n	## Impact The public OIDC login and callback endpoints ran the full flow whether or not OIDC was the instance's active, enabled authentication method, so turning OIDC off in Settings did not stop it issuing sessions. An administrator who disabled the provider still had a working login route. The patch requires OIDC to be the enabled, active authentication method before eith...
CVE-2026-86085	New		MODE		0.003	npm:n8n	## Impact The endpoints `/rest/roles/:slug/assignments` and `/rest/roles/:slug/assignments/:projectId/members` checked only that the caller could manage the role type, not that they could see the project named in the request. A user holding role-management permission could therefore name any project on the instance and read back its members' names and email addresses. The p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86993	New		MODE		0.003	npm:n8n	## Impact A log streaming event destination may reference a generic HTTP credential, and the destination resolved and decrypted whichever credential it named without checking that the caller had access to it. A user holding a custom global role scoped to Log Streaming operations could therefore name a credential belonging to another project and have its decrypted secret sen...
CVE-2026-86994	New		MODE		0.002	npm:n8n	## Impact The endpoint `/rest/active-workflows` returned every active workflow ID on the instance to any member, regardless of sharing, and workflow activation, deactivation and publication push events were broadcast to every connected client, carrying workflow IDs, version IDs and activation-error detail across users. The patch scopes both the listing and the push events t...
CVE-2026-86995	New		MODE		0.003	npm:n8n	## Impact The Git node validated the repository that a fetch or pull targeted, but `setUpstream` wrote a `branch.<name>.remote` value into the repository's own configuration without validating it. A subsequent fetch or pull resolved the remote from that configuration rather than from the checked parameter, so an authenticated user with workflow-edit permission could point i...
CVE-2026-87804	New						Rejected reason: no security impact
CVE-2026-88000	New				0.003	PyPI:open-webui	## Summary Chat histories are stored as an unvalidated JSON object. After a message is deleted, the code that picks the chat's new current message walked down the `childrenIds` links without recording where it had already been. Any account with the default `user` role could store a chat whose messages list each other as children, then delete a message from it, and the walk w...
CVE-2026-88001	New				0.003	PyPI:open-webui	## Summary Open WebUI protects server-side web fetches with two controls: the operator's list of excluded hosts, and a check that refuses private and internal addresses. Neither control was applied to the destination of an HTTP redirect. On a deployment where redirect following is enabled, any authenticated user who can cause the server to fetch a URL could submit a page th...
CVE-2026-88002	New				0.003	PyPI:open-webui	## Summary Chat histories are stored as an unvalidated JSON object. The walk that reconstructs a chat's message chain detected repeats using each message's own `id` field while moving through the history by map key, so a message that simply omitted `id` was never recorded as visited. A history whose messages referenced each other in a parent cycle therefore made the walk run...
CVE-2026-9768	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-9769	New				0.003	PyPI:justhtml	#### Summary justhtml through 1.9.1 allows denial of service via deeply nested HTML. During parsing, `JustHTML.__init__()` always reaches `TreeBuilder.finish()`, which unconditionally calls `_populate_selectedcontent()`. That function recursively traverses the DOM via `_find_elements()` / `_find_element()` without a depth bound, allowing attacker-controlled deeply nested inp...
CVE-2026-9856	New				0.003	PyPI:transformers	A vulnerability in huggingface/transformers versions < 5.10.0 allows an attacker to perform arbitrary file writes via path traversal. The issue resides in the `save_pretrained()` methods of `PreTrainedTokenizerBase` and `ProcessorMixin`, where keys from the `chat_template` dictionary are used directly as filenames without proper validation. An attacker can exploit this by pu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-57v5-wqx3-cgj4	New					Go:github.com/siyuan-note/siyuan/kernel	SiYuan: Database view structure (all view names, layout types and per-field visibility) is returned to anonymous readers by /api/av/getAttributeViewFieldViews in github.com/siyuan-note/siyuan/kernel
GHSA-x7m8-jrm8-hpvx	New		HIGH			npm:@eigenpal/docx-editor-core, npm:@eigenpal/docx-editor-react	## Summary Embedded font-family names (`word/fontTable.xml`) were interpolated unescaped into an injected `@font-face` ` <style>` and into the print window's `document.write()`. A crafted name injects page-wide CSS on open, and breaks out of `<style>` into executable HTML on Print. ## Impact Opening a crafted `.docx` applies attacker-controlled CSS page-wide with zero clic...</td></tr> <tr> <td>MAL-2026-16111</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-aggregator</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d7d5f0fb8c06c23afad28686a3d3d689dfc5a3786c73bff2c569fd8b55f2b4ad) The package's preinstall.js lifecycle script executes automatically on `npm install` and performs reconnaissance on the installer host. It collects hostname, username, current working directory, platform, and the output ...</td></tr> <tr> <td>MAL-2026-16112</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-analytics</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (bfe27d37497e77c8f0eca9105a6b64c646c7ef1439c05ec50edaf40215037f92) etoro-analytics@99.0.2 ships a preinstall lifecycle script (preinstall.js) that automatically runs on `npm install`. The script collects installer host identifiers (hostname, username, cwd, platform) and issues an initia...</td></tr> <tr> <td>MAL-2026-16113</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-api</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ab6228f994962694d4434f53d20d6a5a1b877b39a3498236327da9d0385284d9) The preinstall lifecycle script in etoro-api@999.0.0 (preinstall.js) auto-executes on npm install and performs an HTTP GET to a hardcoded bare-IP endpoint at http://209.126.81.147/etoro-depconf-poce346552f776f/npm/<host>...</td></tr> <tr> <td>MAL-2026-16114</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-auth</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (385c1c361c59557137d095062a9f767a4c0cd0a1ef78b0b26e4654147e137e3c) The package's preinstall.js runs automatically on `npm install` and collects host identifiers (os.hostname(), os.userInfo().username, process.cwd(), process.platform), sending them via HTTP GET to a hardcoded bare-IP end...</td></tr> <tr> <td>MAL-2026-16115</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-billing</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (3c1ceae274b450706288722b9f6c049114593ef2671de93ac58c4fd4a7318c9a) On `npm install`, the package's `preinstall` lifecycle hook executes `preinstall.js`, which reads `os.hostname()`, `os.userInfo().username`, and `process.cwd()` and issues an HTTP GET to `http://209.126.81.147/etoro-depc...</td></tr> <tr> <td>MAL-2026-16116</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-builders</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c9210fb131a2f661ae1d656fa461d45c6c54377179aecba06e6a07b4f357a00b) The package's preinstall lifecycle script (preinstall.js) reads the installer's OS hostname, username, and current working directory via os.hostname(), os.userInfo().username, and process.cwd(), encodes them into a URL p...</td></tr> <tr> <td>MAL-2026-16117</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:etoro-cashout</td><td>--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (c8aa14d0b9945053b63f4396f09365c5daefec60a25e931f165b3473e7c564f1) The package's preinstall.js lifecycle script runs on npm install and executes host reconnaissance commands (whoami, ipconfig/ip addr, directory listings of C:\ and /, tasklist/ps, and a full environment-variable dump via...</td></tr> </table> </div></style>

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16118	New					npm:etoro-charts	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (e44aff5a1a0b68ff9c9b3456693ef1b8266dce7001dd8b6ff56bed428bbc7c5a) On npm install, preinstall.js runs automatically and sends the installer's hostname, username, platform, and current working directory via HTTP GET to http://209.126.81.147/etoro-nuget-verify1f8eaa57a875/npm/v2/<host>/<u...
MAL-2026-16119	New					npm:etoro-client	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d31819832ff4b43fc9bc7bcd9f3439f71902802331ba6df3c3964c47765397e1) The preinstall lifecycle script in etoro-client@999.0.0 unconditionally sends the installer's hostname, OS username, and current working directory to the hardcoded bare-IP endpoint http://209.126.81.147/etoro-depconf-poc...
MAL-2026-16120	New					npm:etoro-core	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (64a03f7bbaa2cb54ffea9a0c98d22bdc2fdb0d368846beefbd8d9c3b5ab3f644) The package's preinstall lifecycle script (preinstall.js) issues an HTTP GET to the hardcoded bare-IP endpoint http://209.126.81.147/etoro-depconf-poce346552f776f/npm/ with os.hostname(), os.userInfo().username, and proc...
MAL-2026-16122	New					PyPI:pylever	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (6720ca3891de59548dfdfc9b6af778b5bf97fb31c5188381c73e92c4ac2820e1) The package's `_Client` class scans Chrome, Edge, and Brave browser profile LevelDB and Cache directories and the Discord Desktop app's Roaming/discord Local Storage/leveldb for strings matching the Discord token regexes...
MAL-2026-16123	New					npm:pinochiomathm	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (135c673bb3925502b10f92d9819d956004ade25faa9c358f6d3fb2c67cd6114e) The package impersonates picomatch (name 'pinochiomathm', description copied from picomatch, homepage pointing at github.com/micromatch/picomach). On require, lib/pinochiomathm.js reads lib/parse.ts.map, base64-decodes i...
MAL-2026-16124	New					npm:tailwindcss-contact-forms	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (cc68c81374c5b78e36fea2f599c5e0004ead6e56dfd02b40cec4f73c62193b30) The package presents itself as a Tailwind CSS forms plugin (README, repository field, and installation docs are copied verbatim from @tailwindcss/forms) but its sole main module src/index.js is a heavily obfuscator.io-ob...
MAL-2026-16125	New					PyPI:lucy-python-script-2030	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (0b93ebbd2207ccfa0d02d068d444dce91835203dfe89a5ece38906158b4d3b891) Starting version 0.1.1, the package contains an infostealer attempting to exfiltrate during import various sensitive data, like browser data, sensitive files, cloud credentials and others. In analyzed versions, the code contained ...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87011	Updated - Fix/version updated		HIGH		0.004	pip:open-webui	## Summary The OIDC back-channel logout endpoint is unauthenticated by design, because the identity provider calls it without a browser session. Before checking whether the submitted logout token was genuine, the handler fetched the provider's discovery document and its signing keys over the network, and repeated both fetches on every request because nothing was cached. The...
CVE-2026-87012	Updated - Fix/version updated		MODE		0.003	pip:open-webui	# Any authenticated user can suppress calendar alerts instance-wide via a non-numeric alert value ## Summary Calendar events carry a free-form `meta` object that is stored exactly as submitted, with no validation of the values inside it. The scheduler reads the per-event alert offset out of that object in a single pass that covers every user's upcoming events, and compares...
CVE-2026-87013	Updated - Fix/version updated		MODE		0.003	pip:open-webui	## Summary Any authenticated user can move one of their own folders under itself, leaving a loop in their folder tree. The re-parent endpoint performed no check that the new parent was not the folder itself or one of its own subfolders, and the folder tree walks did not track which folders they had already visited. A single request against a folder in a loop therefore never ...
CVE-2026-87014	Updated - Fix/version updated		MODE		0.003	pip:open-webui	## Summary A user who is demoted from admin by an identity provider keeps admin-level read and write access to every user's notes, over any Socket.IO connection that was already open when the demotion happened. Open WebUI caches the user's role on the socket at connection time, and the two SSO role-sync paths, the reverse-proxy trusted role header and OAuth role mapping, ch...
CVE-2026-87015	Updated - Fix/version updated		MODE		0.003	pip:open-webui	## Summary When more than one external tool server is reachable in the same request, a tool call to a server configured for bearer authentication can arrive carrying the calling user's Open WebUI session cookies alongside that server's own key. The cookie jar is built per connection, but the callable that performs the request reads it late instead of per connection, so ever...
CVE-2026-87016	Updated - Fix/version updated		HIGH		0.004	pip:open-webui	## Summary On SQLite deployments, the lookup that maps an external identity to a local account does a substring match instead of an exact match. A subject value containing SQL wildcard characters therefore matches accounts the value was never issued for, and the sign-in binds to whichever account the database returns first, which can be an administrator. The same defect aff...
CVE-2026-87017	Updated - Fix/version updated		MODE		0.002	pip:open-webui	## Summary The built-in knowledge search tool returns knowledge bases the calling user has no access to. The tool works out which knowledge bases the caller may read and hands that set to the vector store as a search filter, and that filter is the only access control on the path. Most of the shipped vector backends accept the filter argument on their search method and never ...
CVE-2026-87994	Updated - Fix/version updated		MODE		0.002	pip:open-webui	## Summary Any member of a channel who can post to it could also replace the text of a message written by a different member. The channel branch of the chat completions endpoint checked that the caller may write to the channel, and that the targeted message belongs to that channel, but never checked that the caller actually wrote the message being edited. The message kept it...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87995	Updated - Fix/version updated		HIGH		0.002	pip:open-webui	## Summary Any authenticated user with access to a shared terminal server could get script of their choosing to run in the Open WebUI origin itself. The in-app port preview rendered the content of a previewed port in an iframe whose sandbox always granted `allow-same-origin` alongside `allow-scripts`, and that content is served from a path on the application's own origin, so...
CVE-2026-87996	Updated - Fix/version updated		HIGH		0.002	pip:open-webui	## Summary With the Playwright web loader enabled, Open WebUI checks the address behind a user-submitted URL before allowing the request, then handed the request to the browser to perform. The browser resolved the hostname a second time, on its own, and that answer was never checked. An attacker who controls the authoritative DNS for a hostname they submit can answer the fir...
CVE-2026-87997	Updated - Fix/version updated		MODE		0.002	pip:open-webui	## Summary The chat-completions endpoint reads a folder id out of the request body and saves the newly created chat into that folder without checking that the caller is allowed to write there. Any authenticated user who knows a folder's id can put a chat of their own into another user's folder, including a shared folder where they hold read-only access and a folder they have...
CVE-2026-87998	Updated - Fix/version updated		HIGH		0.003	pip:open-webui	## Summary External knowledge connections are created and owned by administrators, and are shared by every external knowledge base bound to them. Deleting an external knowledge base also removed that connection from the instance configuration, with no check on the caller's role and no check for other knowledge bases still using it. Any authenticated user holding a write gran...
CVE-2026-87999	Updated - Fix/version updated		HIGH		0.002	pip:open-webui	## Summary Open WebUI fetches user-supplied URLs on the server for RAG URL ingestion and web search, and screens the resolved addresses so internal destinations cannot be reached. That screen decided whether a destination was external by asking Python's standard library whether the address is globally routable. Several addresses reserved for internal use answer yes to that ...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704	Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-42016	Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018	Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-67277	Added to KEV			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76460	Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461	Added to KEV			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-84869	Added to KEV			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706	Added to KEV			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-86060	Added to KEV			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-87886	Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-60004	New				0.868	Go:code.gitea.io/gitea, Go:gitea.dev	Gitea: Remote Code Execution via diffpatch Git Hook Installation in gitea.dev

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77770	New	10.0	CRIT		0.002		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not require a validated transaction before deleting site options whose names come from unauthenticated request input, allowing any visitor to delete arbitrary options, which can lock every administrator out of the dashboard or deactivate every miniOrange 2FA WordPress plugin...
CVE-2026-19583	New	9.9	CRIT		0.006		Velociraptor allows some sensitive artifacts to be gated by additional permissions. For example, the Linux.Sys.BashShell artifact allows arbitrary command execution on endpoints, and so it requires the EXECVE permission to schedule. However, no such check was implemented for client monitoring artifacts. Additionally there was no requirement that client monitoring artifacts c...
CVE-2026-68487	New	9.9	CRIT		0.004		Path traversal in Plesk's Backup Manager causes arbitrary file write as root by an authenticated customer.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68488	New	9.9	CRIT		0.002		A Time-of-check Time-of-use (TOCTOU) race condition leading to insecure symlink following in Plesk causes local privilege escalation to root via arbitrary file/directory ownership takeover.
CVE-2026-89094	New	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2026-18351	New	9.8	CRIT		0.008		The Drag and Drop File Upload for Elementor Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.6.0 via the elementor_file_upload function. This is due to insufficient file type validation in the is_file_type_valid() function, which uses the attacker-controlled 'type' parameter as regex keys in the MIME allowlist, allowin...
CVE-2026-38626	New	9.8	CRIT		0.003		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-52098	New	9.8	CRIT		0.008	flowiseai:flowise	An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowId> endpoint
CVE-2026-57967	New	9.8	CRIT		0.007	apache:artemis	An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-7188	New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows SQL Injection. This issue affects Access Control System: before Versiyon 2.
CVE-2026-78573	New	9.8	CRIT		0.004	ibm:contextforge	IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-79724	New	9.8	CRIT		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-80351	New	9.8	CRIT		0.005	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privile...
CVE-2026-80352	New	9.8	CRIT		0.004	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9...
CVE-2026-81204	New	9.8	CRIT		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81467	New	9.8	CRIT		0.038	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-85025	New	9.8	CRIT		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-88018	New	9.8	CRIT		0.005	rclone:rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, wh...
CVE-2026-88278	New	9.8	CRIT		0.003		GeoVision GV-LPC2211 V1.13 fails to enforce WS-Security UsernameToken freshness or nonce reuse protection, allowing a captured PasswordDigest token to be replayed for subsequent ONVIF operations.
CVE-2026-9163	New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.
CVE-2026-82107	New	9.6	CRIT		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-44950	New	9.5	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) copies each glyph's bitmap into a single buffer. Existing checks validates only that the source slice (position, length) lies within the source bitmap buffer. It does not check whether the running destination cursor has exceeded the allocation. A malicious font server can send overlapping source offsets ...
CVE-2026-65639	New	9.5	CRIT		0.016		OS command injection in the advanced-rule parser of ConfigServer Security & Firewall allows a remote attacker who controls a configured allow/deny feed to execute arbitrary commands as root, due to insufficient validation of feed-supplied rule data. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-...
CVE-2026-88062	New	9.5	CRIT		0.009	npm:omniroute	OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called re...
CVE-2026-81046	New	9.4	CRIT		0.004	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88285	New	9.4	CRIT		0.003		GeoVision GV-LPC2211 V1.13 exposes a network-accessible PTZ control service without authentication, allowing remote clients to retrieve PTZ information and issue PTZ or raw serial commands.
CVE-2026-75940	New	9.3	CRIT		0.003		A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.
CVE-2026-78082	New	9.3	CRIT		0.005		Joomla Extension - joomshaper.com - Unauthenticated SQL Injection in Property Search and Map Filtering in SP Property < 4.1.4 - The property search and listing query builders assembled several WHERE and ORDER BY clauses (zipcode, sorting, price_range_dropdown, and psize_range_dropdown) by directly concatenating raw request parameters into SQL strings without quoting or type ...
CVE-2026-81800	New	9.3	CRIT		0.002		Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-8323	New	9.3	CRIT		0.003		URL redirection to untrusted site ('open redirect') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows Fake the Source of Data. This issue affects Access Control System: before Versiyon 2.
CVE-2026-88864	New	9.3	CRIT		0.003		Capgo (capgo.app) fails to restrict direct write access to the public.sso_providers table exposed through Supabase PostgREST. A holder of an ordinary Capgo full API key can insert a row with status='active' and enforce_sso=true, bypassing the intended backend SSO provisioning route (supabase/functions/_backend/private/sso/providers.ts) and its controls: the Enterprise plan r...
CVE-2026-88866	New	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the L...
CVE-2026-88867	New	9.3	CRIT		0.003		WWBN AVideo, in versions up to and including commit c3edcc274c389816d434acadac07ee78eaf330c1, contains a stored cross-site scripting vulnerability. objects/categoryAddNew.json.php passes the POST parameters `name` and `iconClass` to Category::setName() and Category::setIconClass(), which store the values without sanitization (setName only truncates to 45 characters). The cat...
CVE-2026-88868	New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LiveLinks plugin where title and description fields are stored without sanitization. A user with canStream permission can inject malicious scripts that execute in the browser of every visitor viewing the live-link page, including administrators, within t...
CVE-2026-88869	New	9.3	CRIT		0.005		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the AD_Server plugin's log.php endpoint that fails to escape the label parameter before storage. An unauthenticated attacker can inject malicious HTML through the label parameter, which is later rendered unsanitized in the admin Ad Types report using jQuery ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88877	New	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only...
CVE-2026-88899	New	9.3	CRIT		0.004		knowns versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89042	New	9.3	CRIT		0.003		passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-13745	New	9.2	CRIT		0.003		A vulnerability in the Gemini CLI and associated GitHub Action allowed an unprivileged attacker to achieve an arbitrary code execution in Gemini CLI via untrusted local .env files overriding GEMINI_CLI_HOME.
CVE-2026-59679	New	9.2	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) indexes the per-character encoding[] array using num_chars from the FS_QueryXBitmaps16 reply, but that array was allocated with a size derived from num_extents in the separate FS_QueryXExtents16 reply. The two CARD32 fields are never cross-checked. A malicious or compromised font server can send a small n...
CVE-2026-65638	New	9.2	CRIT		0.032		Improper escaping of a request URL in ConfigServer Security & Firewall allows an unauthenticated remote attacker to execute arbitrary commands as the CSF service account via shell command injection. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPross-maintained fork that contain the vulnerable code. ...
CVE-2026-88881	New	9.2	CRIT		0.003		Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the 'next' page. Because the pagination URL is not validated against the host originally contacted, a...
CVE-2026-88882	New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. In versions before 44.11.2 (and Mend Renovate CE/EE images and charts before 15.4.0, and mend-renovate-enterprise-edition helm chart before 10.4.0), when listing new package versions from a NuGet registry Renovate follows pagination URLs supplied by the registry in the HTTP `Link` header without verifying that the target has t...
CVE-2026-88887	New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. When listing tags/digests for a container image, Renovate follows pagination links supplied by the remote registry in the HTTP Link header and attaches the registry credentials to the follow-up request without verifying that the pagination URL has the same origin as the original registry. A malicious or compromised container r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19646	New	9.1	CRIT		0.005		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-45764	New	9.1	CRIT		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workarou...
CVE-2026-49364	New	9.1	CRIT		0.004	apache:artemis	An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-67593	New	9.1	CRIT		0.006	apache:artemis	A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to versi...
CVE-2026-68006	New	9.1	CRIT		0.004		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file
CVE-2026-71640	New	9.1	CRIT		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline
CVE-2026-78361	New	9.1	CRIT		0.003		The zipMoney(Zip Co) Payments Plugin for WooCommerce WordPress plugin before 2.4.0 does not perform any authorisation checks on one of its front-end request handlers, and does not restrict which option name a caller may supply, allowing unauthenticated users to delete arbitrary WordPress options. This can be used to destroy site and access control configuration, deactivate e...
CVE-2026-80424	New	9.1	CRIT		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-84939	New	9.1	CRIT		0.008	apache:freemarker	Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling lo...
CVE-2026-88007	New	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authen...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88008	New	9.1	CRIT		0.003	traefik:traefik	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.26 until 2.11.57 and 3.7.13, Traefik forwards a client-supplied Connection header requesting Upgrade, the Upgrade: h2c token, and HTTP2-Settings to a shared backend. If the backend accepts h2c and returns 101 Switching Protocols, Traefik enters a raw tunnel and no longer applies routers, BasicAuth, For...
CVE-2026-88044	New	9.1	CRIT		0.005	go:github.com/rclone/rclone	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.70.0 until 1.75.1, the serve/start RC interface accepts per-server proxyOpt.AuthProxy settings, and the FTP and S3 constructors in cmd/serve/ftp/ftp.go and cmd/serve/s3/server.go incorrectly check the process-global proxy.Opt.AuthProxy value instead. When the ...
CVE-2026-89086	New	9.1	CRIT		0.002		In the jose package before 0.11.0 for OCaml, library calls to validate an RSA signature only confirm that PKCS #1 decoding succeeds, and proceed to declare the signature valid without the required steps that involve the public key.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.